Threat Intelligence

Threat evolution in Q4 2019

January 2020

group-ib.com

Contents

INTRODUCTION **3**

EXECUTIVE SUMMARY **4**

Targeted attacks on the financial sector 4

Financial threats 4

Threats to the government sector 5

Data leaks 7

FORECASTS FOR Q1 2020 **9**

ADVANCED THREATS IN THE FINANCIAL SECTOR **10**

FINANCIAL THREATS **17**

Malware for Android 18

Threats and malware for PC 20

Attacks on ATMs and POS terminals 34

STATE-SPONSORED APTS **37**

DATA LEAKS **60**

Introduction

Every quarter Group-IB releases a report on the development of high tech cyber-crime, featuring new tendencies, emerging trends, and predictions on the cyber-threat landscape.

The most dangerous threats have been attacks on the financial sector. This report features threats with a particular focus on Europe, Russia, the US, Canada, and Australia. This document also provides a comprehensive description of threats to governments, including targeted attacks supported by governments and significant data leaks.

To collect data and inform our clients, we analyze various botnets and malware while conducting incident response, monitoring underground forums and accumulating information on new trends, threats, and data leaks. Every day we research thousands of compromised credentials, bank card numbers, hackers' accounts, messages, and announcements on the dark web, as well as tens of thousands of attacks, which enables us to promptly notify you of threats targeting your company and clients.

Executive summary

Targeted attacks on the financial sector

Q4 2019 saw the following APT campaigns against financial organizations:

- New tools (RDFsniffer, boostwrite) of the Fin7 group (Russia) have been discovered. In addition, security specialists periodically detect files used by Fin7 to distribute the Griffon malware.
- The Cobalt group continued to attack financial organizations. All of the attacks involved the distribution of the Coblnt malware. The threat actors used phishing emails to send out files with macros and password-protected archives with an executable within. The latest emails contained links to .pdf files or attached files that contained a link to download the Coblnt stager.
- Group-IB specialists discovered that the Silence threat group carried out attacks on ATMs in Africa. The attack involved XDA.Launcher and XDA.RAT.
- Lazarus (North Korea) is carrying out a campaign against crypto traders. Programs JMT Trader and Union Crypto Trader were created for that purpose. Launching them leads to Windows and Mac backdoors being downloaded. In addition, the group carried out phishing mail-outs posing as Hindustan Aeronautics and Las Vegas Consumer Electronics Show 2020. The attacks distributed the Manuscrypt Trojan. We also detected the use of a new loader called CuriousLoader.
- A bank in the Asia-Pacific region was attacked, it was reported. The attack involved the Cosmosis Trojan.

Financial threats

- Active attacks involving RTM continue in the post-Soviet region: Russia, Kazakhstan, Ukraine, Belarus, and Azerbaijan.
- In late December 2019, emails containing a modified version of RMS with a backdoor feature were sent out to Russian companies.
- Group-IB specialists concluded that Servhelper backdoor, a tool used in Silence and TA505 attacks, might be up for sale on underground forums. A post advertising the rent of HRDP-type malware was discovered. The poster was the user with the nickname leap. Group-IB specialists contacted the seller to obtain additional information and were able to get test access to the tool. Analysis of the sample revealed that it is Servhelper with a high degree of likelihood. This means that the Trojan cannot be automatically attributed to TA505.
- Two large databases with compromised cards and dumps were published on Joker's Stash, a card shop. One of them, called TURKEY-MIX, contains Turkish cards, a total of about 500,000. The second one, called NEW WORLD ORDER BREACH, contains dumps of US cards, about one million (new data from this database will potentially be added in the future). As for the dumps, a POS Trojan was likely used. Group-IB specialists identified what companies were infected. A database of Philippine banks was found on the same resource. It had fewer compromised cards and dumps, a total of about 10,000.
- FIN8 carried out attacks on fuel stations in North America with the aim of installing POS malware.
- FIN6 hackers conducted a large-scale campaign involving credit card skimming attacks, which were active in 3,126 online shops.
- The RevengeHotels and ProCC threat groups are carrying out a campaign with the aim of compromising bank card data that is stored in the information systems of hotels as well as data received from travel agencies.

- Restaurant chains Moe's Southwest Grill, Schlotzsky's, McAlister's Deli, Catch Hospitality Group, and Krystal burgers in the US were infected with POS Trojans.
- We did not detect any new POS Trojans being sold on underground forums.
- A new Trojan for Diebold Nixdorf ATMs was put up for sale on underground resources. The seller is a user with the nickname Fear.
- A new version of Anubis, an Android banking Trojan, emerged. In addition, a new Android bot called BFG was put up for rent.
- A new version of the Axe bot malware for Windows appeared. It was named Silent Night.
- Group-IB specialists analyzed a malicious campaign that involved the Proxy Changer technique being used in Latin America. A malicious program that steals banking credentials of various financial organizations was discovered.
- Malware for brute forcing the admin panels of various e-commerce and CMS platforms was put up for sale on an underground forum (the seller is bruteguru).
- An EternalBlue exploit–based loader was released by a user named ghostrider.
- Two new malicious programs for Windows were put up for sale: HVNC and RAT with VNC functionality.
- FlexNet remains the most active banking Trojan for Android in Russia.
- The Gozi Trojan was active in Australia, New Zealand, and Italy.
- TrickBot was detected in the US, the UK, Germany, Poland, and Japan. We should note that we did not detect Japanese banks among its targets in Q3 2019.
- The Danabot banking Trojan was observed in attacks on banks in Australia and Poland.
- Like in the previous six months, IcedID has been attacking targets in the US, Canada, and the UK.
- Gookit activity declined; banks in Italy, Austria, Germany, and the US were attacked.
- Ramnit is active in Japan.

Threats to the government sector

Governments are always going to be under the threat of cyberespionage and in some cases suffer attacks on critical infrastructure. Group-IB specialists perform an independent analysis of such threats and are well-informed about the results of global expert studies. The following APT campaigns against government organizations were detected in Q4 2019:

- Lazarus hackers (North Korea) gained access to the data of a senior manager at the Nuclear Power Corporation of India Limited (NPCIL) using a tool called Dtrack. The hackers continued the attack, in which they compromised India's Kudankulam Nuclear Power Plant. In addition, they were observed using Dacls, a new type of remote-control malware for Windows and Linux.
- The Chinese threat group Calypso carried out attacks against government agencies in India, Brazil, Kazakhstan, Russia, Thailand, and Turkey.
- Patchwork, an Indian hacker group, continues its cyberespionage campaign against Pakistan, reusing the Kashmir issue as a way to fuel conflict.
- Attacks by the APT37 group (North Korea) against Chinese and South Korean traders were discovered. The hackers are also carrying out a campaign called Dragon Messenger against North Korean defectors, targeting mobile phones.
- The Chinese threat group APT31 was observed using a new tool called skip-2.0, which is designed to alter MSSQL functions responsible for authentication.

- The North Korean group Kimsuky continued their malicious actions against South Korea under the guise of agreements with the US and Vietnam. The campaign was dubbed Operation Blue Estimate.
- Another Chinese hacking group was active in this period—APT5. The group targeted corporate VPN servers from Fortinet, Pulse Secure, and Palo Alto.
- The Mustang Panda hacker group (China) attacked a large range of governmental and non-governmental organizations and national minorities using PlugX and Cobalt Strike.
- Charming Kitten (Iran) carried out a cyberespionage campaign against current and former US government officials, journalists, and Iranians living outside Iran.
- A group or several groups called PKPLUG (China) was discovered. PKPLUG has been conducting a cyberespionage campaign in and around South-East Asia since 2013.
- A campaign called Ghost by APT29, which started in 2013 and targeted European ministries of foreign affairs, was uncovered. The hackers used new malware, namely PolyglotDuke, RegDuke, FatDuke, and LiteDuke as well as a previously documented program, MiniDuke.
- A South Korean group called Higaisa and active since at least 2016 was discovered.
- Turla (Russia) carried out a campaign against Russia and Belarus using a new malicious program called Reductor. In addition, malware called Tunnus was discovered; it is attributed to the Turla group with some degree of confidence. Specialists established that the group used the infrastructure of OilRig during their attack on a Middle Eastern organization in 2018.
- A mining organization in Kazakhstan is believed to have been attacked by APT28 (Russia).
- A campaign called WizardOpium was discovered. It is based on the exploitation of zero-day vulnerabilities CVE-2019-13720 and CVE-2019-1458. The Darkhotel group (North Korea) may be behind the campaign.
- The OceanLotus group (Vietnam) extended their list of target programs to carry out attacks using the DLL side-loading technique. The threat actors continue to use Denis, Cobalt Strike and, in some cases, Gh0st as payloads. The group disguised their malicious applications as system utilities for Android. One of the applications had more than 5,000 downloads on Google Play. According to certain information, the group targeted car manufacturers such as BMW and Hyundai in the spring of 2019.
- The OilRig group (Iran) used a new wiper called ZeroCleare to attack the oil and gas industry in the Middle East. The wiper shares certain characteristics with the infamous Shamoon malware in that they both use EldoS's Raw Disk, a legitimate driver, for low-level access to the hard disk.
- APT33 (Iran) deployed their own network of VPN servers for C&C communication to operate a botnet. The campaign targeted organizations in the Middle East, the US, and Asia. Traces of infection were found in military organizations, universities, and colleges in the US.
- New details about the GALLIUM campaign (China)—which we track as Soft Cell—emerged. The campaign targets telecommunications companies worldwide. The threat actors exploit vulnerabilities in WildFly, an open-source application server.
- The Chinese hacker group Platinum resumed their attacks against the Asia-Pacific region using a new backdoor, which was dubbed Titanium.
- Hackers formerly known as AVIVORE are behind the attack on Airbus, it has been established. The threat actors employed an island hopping technique and compromised the aerospace company's suppliers.
- Gamaredon (Russia) continues its attacks on Ukraine, this time targeting the Ukrainian Ministry of Foreign Affairs, NGO media watchdog Detector Media, and the Dnipro Control System.
- APT-C-35 extended their list of targets and exploited the CVE-2018-0802 vulnerability in Microsoft Equation in their attack, as well as components of the yty framework.
- APT20 hackers (China) conducted Operation Wocao for two years. The campaign targeted industries such as aviation, construction, finance, health care, insurance, gambling, and energy.

- Rancor (China) continues its attacks against South-East Asia, in particular, a government organization in Cambodia, using the Dudell Trojan.
- The BlackTech group continues to improve their tools as part of their Waterbear campaign. The threat actors hook APIs to avoid being detected.
- The Chinese hacker group Tick was observed using new tools in a campaign called Operation ENDTRADE against the Chinese defense and chemical industries.
- The activity of the Golden Falcon group was discovered. The threat actors' targets are private individuals and organizations in Kazakhstan.
- APT-C-37 carried out two targeted attacks against Palestine to affect the Palestinian national elections.
- Domestic Kitten hackers (Iran) continued their espionage campaigns against the enemies of the Islamic Republic of Iran. The hackers attacked the Android platform.
- The BITTER group (India) launched a new campaign against the Chinese military industry using SlideRAT, a previously unknown Trojan for Android.

Data leaks

- Canadian medical company LifeLabs had to pay a ransom to threat actors who had gained access to information on 15 million customers.
- Phone manufacturer OnePlus reported that the data of their online store customers had been compromised.
- Information security experts discovered an unsecured server with data provided by People Data Labs and OxyData. It contained information on four billion user accounts.
- A 179-GB cloud storage database of Best Western, a hotel chain, was exposed online.
- Online game developer Zynga was hacked, with 170 million users affected.
- An unsecured Elasticsearch database with information on 267 million Facebook users was discovered, a security researcher reported. The database was left exposed on the web for about two weeks. At the moment, access to it is closed.
- An unsecured Elasticsearch server of Honda North America was discovered. The data leak affected 26,000 customers.
- On November 27, an unknown individual published the details of 15 million bank cards of Iranian citizens, customers of Mellat, Tejarat, and Sarmayeh banks.
- In November 2019, hacker Phineas Fisher announced that back in 2016 they hacked Cayman Bank and Trust Company, an offshore bank, and stole the documents and emails of its employees. The hacker made 2 TB worth of the bank's data public.
- A database with information on over 100 million customers of TrueDialog, an SMS provider for businesses and higher education institutions, was found exposed online.
- The Singapore Accountancy Commission published a database with 6,541 entries containing personal data.
- German mobile operator T-Mobile reported a large data leak that affected over one million customers.
- Researcher Troy Hunt said the personal information of 1.4 million customers of GateHub, a cryptocurrency platform, was exposed online.
- TennCare, a state Medicaid program, reported a data leak that affected over 40,000 TennCare members and contained names, social security numbers, health plans, and the names of prescribed drugs.

- In Malaysia, the BreachDB hacker group said they had data on 50,000 students of Universiti Malaysia Sabah.
- ESET specialists discovered a misconfigured Elasticsearch database containing the personal data of Colombian citizens. The database has over 2.5 million entries.
- An unsecured server of Pouring Pounds Ltd (UK) with data on customers in the UK and India was found exposed. The data leak affected over three million individuals.

Forecasts for Q1 2020

- The main interest to the energy sector will be coming from APT groups that researchers link to Iran, Russia, and North Korea. We forecast that supply chain attacks will become threat actors' main attack vector. Management companies will be attacked first and used as a stepping stone to get to energy companies.
- RTM will be a threat to legal entities in Russia and Belarus.
- Silence is becoming one of the most active and aggressive financially motivated hacking groups out there. New Silence attacks can be expected in the APAC region. We believe that the threat actor may send out "recon" emails with no malicious payload in order to conduct reconnaissance, expand the geographical scope of their attacks, and understand what cybersecurity solutions are used in a particular bank. The recon mail-outs result in the creation of a "target" list of email addresses that will be used for mail-outs with malicious attachments.
  We also believe that Silence imitators may start to operate in Russia and other post-Soviet countries.
- Fin7 will continue their attacks in Russia.
- Cobalt will continue their attacks both within and outside Russia.
- Credit card sniffers will remain a threat. Group-IB specialists regularly detect infections on many websites.
- Infection of POS terminals at companies that receive payments (such as restaurants, hotels, and fuel stations) will remain a threat.
- A big number of JS sniffers and POS Trojans will result in the sale of new sets of compromised cards on underground resources.
- Infection of POS terminals in North America will be carried out by the FIN8 group.
- As we forecast before, the Anubis Trojan will remain a threat to Android. This is facilitated by the appearance of new versions of this malware.
- Malware for Windows such as HVNC and RAT with VNC functionality may be used in targeted attacks as a result of their being put up for sale/rent.
- FlexNet will be an active banking Trojan for Android in Russia.
- Gozi (Ursnif/ISFB) will be a threat in Australia and Italy. The malware may also be active in Japan and other European countries apart from Italy.
- Trickbot will be one of the most active banking Trojans in the US and Europe. In addition, thefts in Japan will increase.
- The Ramnit banking Trojan will be a threat in Japan.
- Thefts using Danabot will occur in Australia, Poland, and, possibly, in the United States.
- IcedID attacks will continue mainly in the US and Canada.
- Gootkit will be focused on Germany, Austria, and Italy.

Advanced threats in the financial sector

333

APT name	Regions attacked	Operation start
Fin7	Global	May 2019

In October 2019, security specialists discovered new tools of the Fin7 group: boostwrite, RDFsniffer.

Boostwrite is a dropper crafted to be launched through the DLL search order hijacking technique. The execution of Boostwrite is as follows:

1) Creation of a text file that will log the malware execution process.
2) Extraction of a key to decode data that contains an IP address to retrieve a key and initialization vector (IV).
3) Decryption of the payload (Carbanak or RDFSniffer) using the ChaCha algorithm and the key and IV obtained during the previous step.
4) Loading of the decrypted payload into memory.

RDFsniffer allows an attacker to monitor and tamper with legitimate connections made via NCR Corporation's Aloha Command Center Client (RDFClient). RDFsniffer loads into the same process as the legitimate RDFClient and launches each time Aloha Command Center Client is executed. RDFSniffer capabilities can be divided into two groups:

- Hooking Win32 API functions to man-in-the-middle SSL sessions or socket connections, hijacking the utility's user interface (UI), and changing the user's last input time.
- Injecting commands (download, upload and delete a file and execute a command) into an active RDFClient session.

It is probable that some NCR customers may have fallen victim to Fin7 attacks that involved these malicious programs.

Further, in Q4 2019 security specialists continued to detect malicious files associated with Fin7. Those are .xlsb files with a malicious macro. Enabling the macro results in the Griffon malware being downloaded. The JScript code contains several functions in its body: to send a signal to the command and control (C&C) server to receive commands, to encode data transferred to the C&C server, to search for DNS hosts for further data transfer, and to send data to the C&C server through DNS or HTTP. If the victim is of interest to the attackers, they execute custom commands and/or launch a backdoor. Group-IB specialists detected IP addresses that may be linked to Fin7. Later, domains that acted as C&C servers when interacting with the discovered Griffon samples were registered with these IP addresses.

Fin7 is a financially motivated Russian-speaking criminal group active since 2015. The threat actors use social engineering techniques and periodically update their attack methods and tools in an effort to bypass detection mechanisms. Most of their attacks target hospitality and restaurant businesses in Europe and the United States.

APT name	Regions attacked	Related notifications	Operation start
Cobalt	Global	CP-1438-76 — CP-1438-82, CP-2096	2016

In Q4 2019, Cobalt carried out numerous malicious mail-outs. All of the attacks involved the Coblnt malware being installed as the final payload:

- On September 25, 2019, a compressed .lnk file, which when opened executes powershell.exe with a Base64-encoded command. As a result, a decoy file and a script supposedly containing the Coblnt stager are downloaded from a remote host.
- On October 3, 2019, an email was sent out from the address fujimaki@tsudagakuen.ac.jp. The email had an attachment, "faktura.doc," containing a macro and was written in Polish. When the macro is enabled, a scheduled task is created and an encrypted VBScript is saved to disk. The VBScript is later used to download the Coblnt stager.
- On October 4, 2019, a file that contained a macro and purported to be created by the European Central Bank was discovered. On October 9, another document with the same malicious macro was detected. Enabling the macro downloads the Coblnt stager.
- On October 15, 2019, a document with a malicious macro was discovered. When it is enabled, a scheduled task is created and an encrypted VBScript is saved to disk. The VBScript downloads the Coblnt stager.
- On October 17, 2019, a mail-out with the subject *Выписки* [Extracts] from the address service@bonanzasolutions.com took place. The emails contained a malicious file with a macro, which when enabled creates a scheduled task and saves an encrypted VBScript that is used to download the Coblnt stager.
- On October 22, 2019, a file with a .js container was uploaded to VirusTotal. The execution of the script results in the unpacking of an .exe that is classified as the Coblnt stager.
- On October 23, 2019, a mail-out from the address Team it <service@bonanzasolutions.com> took place, which had earlier been used by Cobalt. The emails had an attachment with a password-protected .rar archive containing a blank .pdf and "Statement.xls .scr," a malicious executable classified as the Coblnt stager.
- On October 24, 2019, a mail-out from the address Daniel Rhames <daniel@militaryhandyman.com> was carried out; the resource militaryhandyman[.]com had been compromised. The emails had a .pdf document that contained a link to download an executable .scr file classified as the Coblnt stager.
- On November 1, the same address, Daniel Rhames <daniel@militaryhandyman.com>, was used to conduct another mail-out. The email contained a .pdf document with a link within, which is activated when the user clicks on it, resulting in the downloading of a malicious file. The original link had been modified using the vk.com\cc service. Following the link downloads a file, which was unavailable at the time of research. However, a file with a name and download date that match the mail-out was found on VirusTotal. Opening this file launches a scriptlet, which downloads and launches the Coblnt stager.
- On November 4, 2019, a CV-looking file was uploaded to ANY.RUN. The detected document contains a short link to download a malicious file. When the user follows the link, they are redirected to a compromised resource, from where the malicious file is downloaded. Opening the document downloads and launches the Coblnt stager.
- On November 21 and 22, 2019, .docx and .txt files were uploaded to ANY.RUN. The files were created under the name of the "Russian Ministry for the Development of the Far East and the Arctic." Inside the documents is an embedded object; clicking on it unpacks the Coblnt loader.
- On November 22, 2019, an email was sent out under the name of Isaiah Hardin emelyan43391osipovichev194@gmail[.]com with a .pdf document attached. The document contains a short link to download a malicious .doc file. The downloaded file mimics a document by SWIFT. Inside is an embedded object; clicking on it unpacks the Coblnt stager into the directory.
- On December 5, 6, and 9, 2019, threat actors spread .pdf files that contained a link to download the Coblnt stager. In particular, emails with the subject "Document verification" were sent out from the addresses Arvest LLC <mcarthysalvdor@gmail.com>, Admin Arvest LLC Europe

<jodystewat@gmail.com>, and Admin Arvest LLC Europe <ryansssykes@gmail.com>; the emails contained a link to download this .pdf file.

Cobalt is a Russian-speaking cybercriminal group active since April 2016. Their attacks target the internal infrastructure of banks and organizations that have common infrastructure with banks (leasing and insurance companies) in Eastern Europe, post-Soviet countries, the Asia-Pacific region, and other areas. Their aim is to gain access to ATM, bank card and interbank transfer management systems. To carry out their attacks, the group mostly uses phishing emails disguised as coming from financial organizations and ATM manufacturers. The emails contain malicious attachments in the form of a document with an exploit or password-protected archive with an executable within.

APT name	Regions attacked	Operation start
Silence	Africa	2019

On November 18, 2019, two files were uploaded to VirusTotal from the Republic of Senegal: “xfs.dll” and “dns.dll.”

“xfs.dll” was classified as xfs-disp.exe. The malware had earlier been used in a Silence attack.

“dns.dll” is a dropper that saves two files:

- %LOCALAPPDATA%\rtksys2.exe — XDA.Launcher
- %LOCALAPPDATA%\rtkdrv2.exe — XDA.RAT

XDA.Launcher ensures persistence and launches XDA.RAT.

The source code of XDA.RAT is based on an open-source project: https://github.com/iagox86/dnscat2. The application supports the following commands:

- 0 — ping command
- 1 — create a cmd.exe process
- 2 — execute a shell command
- 3 — download a file
- 4 — upload a file from the infected device to the C&C server
- 5 — close all connections
- 6 — change the interval of making requests to the server
- 7 — save the %LOCALAPPDATA%\updatea.bin file
- 8 — overwrite the <%XDA_path%>\updatea2.bin file
- 9 — get information about the connected dispenser
- 10 — carry out an ATM jackpotting attack

It is important to note that the functionality for working with ATMs has been borrowed from xfs-disp.exe, which we described earlier in our report on Silence. The source code of XDA.RAT is therefore based on two projects: dnscat2 and xfs-disp.exe.

The application carries out ATM jackpotting attacks similar to xfs-disp.exe, with the only difference being that XDA.RAT can withdraw a specified amount of money from a specified cassette on command from the server.

Silence is a financially motivated cybercriminal group active since 2016. Their attacks mostly target post-Soviet countries, but the group has been gradually going global.

APT name	Regions attacked	Operation start
Lazarus	South Korea, Global	May 2017

Lazarus threat actors continued their attacks using a crypto-trading program that installs a backdoor on their victims' Mac or Windows computers. Analysis of the scheme revealed that it closely resembles a previous operation that involved crypto-trading malware called AppleJeus, which has been attributed to Lazarus.

The hackers developed a website where they advertise a program called JMT Trader.

The threat actors also created a Twitter account to promote both the website and the program, as well as a fake company.

Trying to download the software will redirect you to a GitHub repository with Windows and Mac executable files for JMT Trader. The webpage also contains source code for trading programs for those who want to compile it for Linux. This source code is not malicious.

By using JMT Trader, a user can create various exchange profiles and use it legitimately to trade cryptocurrency. This is because this application and the GitHub page are clones of the legitimate program QT Bitcoin Trader (the same program is used in the AppleJeus campaign).

When JMT Trader is installed, secondary program called CrashReporter.exe is extracted. Once CrashReporter.exe is launched, it connects to the C&C server to receive commands, which will then be executed by the backdoor.

To target Mac users, Lazarus used another crypto-trading program. This time it was Union Crypto Trader.

Analysis revealed the IOPlatformSerialNumber string and reference to "SystemVersion.plist," which are used to gather information about the infected system. The discovered sample is a standard first-stage implant, which beacons to a remote server for a full-featured second-stage implant.

However, there is one rather unique aspect of the first-stage implant, namely the ability to execute the received payload directly from memory.

Once the malware receives the payload from the remote server, it decodes the payload (through "aes_decrypt_cbc") and then invokes a function named "load_from_memory." The "load_from_memory" function invokes a function named "memory_exec2."

The "memory_exec2" function invokes the Apple API NSCreateObjectFileImageFromMemory to create an "object file image" from a memory buffer (of a mach-O file). Following this, the NSLinkModule method is called to link the "object file image." Finally the malware appears to resolve a symbol in the in-memory image and directly executes it. The end result is pure in-memory execution of a remotely downloaded payload.

In October 2019, Lazarus continued their malicious actions as part of their Operation Shape Changer. We earlier reported about the start of this campaign in June 2019.

When affected by decoy files, delivered by email or via Telegram, a messaging app, the victim computer gets immediately infected by malware, with bots obtaining various information. This time the attack was cross-platform, it was noted.

Even though the Windows PowerShell script and the malicious file for Mac represent different platforms, most payload features for additional actions intended by the threat actors and malware are mainly the same.

On October 23, 2019, Lazarus sent out an MS Word document called “JD-HAL-Manager.doc,” which refers to a vacancy at Hindustan Aeronautics.

The document contains a malicious macro with a Base64-encoded loader, which we named CuriousLoader. The macro extracts the loader into the directory %USERPROFILE%\AppData\Local\Microsoft\ThumbNail\thumnail.db and then loads it as a DLL using the LoadLibraryA function. Following this, the DLL, which has been loaded into the process, has the exportable function ShowState invoked with the arguments "<%doc_path%> and <%aes_key%>", where doc_path is the path to the MS Word document (“JD-HAL-Manager.doc”) and aes_key is the key required for the loader’s further operation. It will be used to decrypt the config.

Control is then passed to the ShowState function of the thumnail.db library. This function deletes “JD-HAL-Manager.doc,” adds itself to startup by creating an .lnk file in %USERPROFILE%\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\thumbnail.lnk and launches another copy of itself through rundll32 calling the exportable function SetupWorkStation. This function starts the loader’s full operation.

aes_key, which has been mentioned earlier, is transferred to the SetupWorkStation function as an argument together with four integer arguments:

C:\Windows\System32\rundll32.exe "<%dll_path%>", SetupWorkStation <%aes_key%> 0 0 9109 1

SetupWorkStation checks whether all the command-line arguments are present and valid and then calculates the MD5 hash from aes_key and decrypts the internal config with the obtained key. The encryption algorithm used is AES-128 in CBC mode. In this case the initialization vector (IV) is zero (0x00000000).

Once the config has been decrypted, the program collects system information (user name, computer name, information about logical disks, and the list of running processes), encrypts it using AES, encodes it with Base64, and sends it to the server, receiving the encrypted Manuscrypt payload in response. The payload is decrypted with a separate key from the config.

On October 24, 2019, Lazarus started carrying out spear-phishing mail-outs under the name of Las Vegas Consumer Electronics Show 2020 (CES) with a malicious attachment in the form of an application form to participate in the event.

International Consumer Electronics Show is a consumer electronics exhibition, which is held annually in January in Las Vegas and organized by Consumer Electronics Association.

Threat actors exploit the CVE-2017-8291 vulnerability, which affects Artifex Ghostscript and allows for -dSAFER bypass and remote command execution via .rsdparams.

Lazarus (also known as Dark Seoul Gang, HIDDEN COBRA, and Guardians of Peace) is a cybercriminal group active since 2007. It has been established that its members are from North Korea.

APT name	Regions attacked	Operation start
Attack on a bank in APAC using the Cosmos Trojan	Asia-Pacific region (APAC)	May 2019

In September 2019, a bank in the Asia-Pacific region was attacked and its systems were encrypted by malware.

In their incident response operation, specialists recovered the following programs: Cosmosis Trojan, yLoader loader, and HybirdRansom encryptor package.

The specialists also discovered the traces of four other programs, which were not recovered, as well as several PowerShell scripts.

The scripts belong to the Hentaic0de hacktivist group, while the loader belongs to the IronTiger APT.

The main Trojan, which is called Cosmosis, is used to exfiltrate files and provide threat actors with remote shell with backconnect. The Trojan has a fake compilation date, July 22, 2020.

Cosmosis is launched through a loader called yLoader, a unique program used in 2017 in attacks involving the gh0st RAT in the Asia-Pacific region. In 2018, Bitdefender published a large study of these attacks and linked them to the IronTiger APT group.

In the bank infection incident, the threat actors call themselves CharityWarriors and demand a ransom in Bitcoin. We analysed the specified Bitcoin wallet and established that there are many other wallets linked to the original one. All of them are used by the threat actors to demand ransoms. We also discovered that one of the wallets received $90,000. We believe this campaign had multiple targets with at least three victims.

Based on the discovered traces of malware, it can be argued that the attack started not later than May 5, 2019, when a scheduled task was created. It launches a PowerShell script from an internal server at http://10.X.X.X/i.php.

Emissary Panda (also known as APT27, TG-3390, Bronze Union, Lucky Mouse, Iron Tiger, and TEMP.Hippo) is a Chinese cybercriminal group known since 2010. The group targets aerospace, government, defense, technology, energy and manufacturing industries.

Financial threats

Malware for Android

Threat name	Detection	Regions attacked	Related notifications
Anubis	October 2019	Global	CP-2094

An updated version of Anubis, an Android Trojan, was put up for sale on underground forums. The malware is distributed via Google Play services disguised as legitimate software. The updated Anubis has all the features of the old version, including web fakes, USSD requests, interception and sending of SMS messages, remote access, and so on. Anubis's updated version allows an attacker to gain complete control over an infected device by automatically disabling the Google Protect service.

The seller is the user with the nickname Validolik. We should note that the source codes of the original Anubis had earlier been put up for sale on an underground forum.

Threat name	Detection	Regions attacked	Related notifications
BFG	October 2019	Global	CP-2119

In October 2019, a new Android bot called BFG was put up for rent on xss.is, an underground forum. The bot's functionality includes SMS, calls, contacts, GPS, applications (including banking apps), and injects. The author of the program is a user named "BFG."

According to the post, the software was created from scratch by a team of developers. The bot has the following functionality:

- SMS (reading, hiding, sending)
- Calls (blocking, USSD commands, recording)
- Contacts (collecting contacts)
- Injects (HTML injections, collecting credit card data)
- GPS (obtaining coordinates)
- Loader (downloading and installing an APK)
- Ads
- Push notifications
- Phone blocking
- Analytics (list of applications, application operation time, and much more)
- Source code encryption

It is worth mentioning that this bot does not work in post-Soviet countries.

The price for one month's rent is $2,000. The sale of slots started on November 8, 2019. The author says there are only four slots left that are available for rent. Rent includes:

- Admin panel (for Linux)
- APK file
- Continuous technical support
- Manual

- Code obfuscation
- Bot's integration with any application

The file is about 100 kilobytes. The bot can also work offline.

Screenshot of BFG's admin panel.

Threat name	Detection	Regions attacked
FlexNet	2014	Russia

The Trojan requests device administrative privileges. The request text is masqueraded as a Google Play agreement, which distracts the user and helps access the privileges.

On command from the C&C server, the application can do the following:

- change the C&C server address
- send an SMS message to a specified number
- send bulk SMS messages with a specified text
- forward SMS messages to a remote server
- reply to SMS messages and delete them to conceal the fact from the user
- run USSD requests
- schedule commands: configure a command template for new bots for a particular operator and country

In addition, FlexNet had phishing dialogs added to its functionality. They are disguised as popular applications in order to obtain victims' bank card details. The following fake dialog boxes were detected:
AliExpress
Alpha
Avito
Google Play
MyNewAlpha
telecard
VTB24
Sberbank
Uber

Threats and malware for PC

Threat name	Detection	Regions attacked	Related notifications
Modified RMS	December 2019	Russia	CP-2128

RMS is a legitimate remote access program. However, threat actors can use modified versions of it for malicious purposes. On December 19, 2019, Group-IB specialists observed the start of a mail-out to Russian companies with emails containing a modified version of RMS with backdoor functionality. The emails were sent out under the name of Angarsk Electrochemical Combine, but the actual senders were different.

The emails had an archive attached, which contained two documents and a password-protected archive with malware disguised as Seldon installer (software for working with tenders).

Threat name	Detection	Regions attacked	Related notifications
Compromise of Turkish bank's bank cards	October 2019	Turkey	CP-2109

Group-IB's monitoring of card shops on October 28, 2019, revealed new databases called TURKEY-MIX on Joker's Stash, an underground marketplace for selling compromised bank cards. The databases contained about 60,000 cards of Turkish banks' customers. Later, on November 27, 2019, another two parts of this database were published on the same marketplace, together containing the data of more than 400,000 cards, which is the largest amount of textual card data to ever be put up for sale as part of a single database. Over 99% of the cards in the database belong to Turkish banks. This is unusual and record-breaking for the region.

The compromised data includes information about full credit card numbers, expiration dates, and CVV/CVC codes, as well as cardholder information such as full names, phone numbers, addresses, dates of birth, email addresses, and so on. Such data can be compromised through numerous methods, for example through phishing, malware, JS sniffers, or as a result of breaching a database with bank card data. The source of the compromise of the cards from the TURKEY-MIX database has not yet been identified.

Threat name	Detection	Regions attacked	Related notifications
Silent Night [Russian: Тихая ночь]	November 2019	Global	CP-2108

On November 9, 2019, a user named Axe put up for sale a banking Trojan called Silent Night [Russian: Тихая ночь] on Exploit.in, an underground forum. The malware is an updated version of Axe bot, a banking Trojan that was developed by the same virus writer under the nickname Axe.

The updated Trojan improves and adds on to the functionality of the previous version of Axe bot. The malware was developed using C++ and WinAPI. The admin panel was created using PHP and MySQL.

The banking Trojan works from Ring3 without leaving the low integrity level. The developer says that in order to access a more privileged level, it should be used together with the loader. It is also worth mentioning that the bot and the admin panel interact through HTTPS; TOR is not used.

Like the original, it is intended for theft of confidential data from PCs running Windows XP–10.

The updated banking Trojan has extensive functionality, such as:

- support for source code obfuscation
- support for and edition of web injects in Zeus format
- form grabber support (Google Chrome, Firefox, Internet Explorer)
- theft of cookie files of the main browsers (Google Chrome, Firefox, Internet Explorer)
- interception of HTTP/HTTPS requests
- support for socks5 backconnect (works on Windows only)
- temporary blocking of access to specific URLs
- blocking of request logging for specific URLs
- keylogger for all running processes
- support for creating a series of screenshots in the areas where the mouse and/or buttons are used.

The developer specified the following characteristics of the Trojan that complicate its analysis:

- the Trojan's code is polymorphic
- the strings and constants are encrypted and are decrypted "on the fly"
- required WinAPI functions are searched by their hashes
- there are fake WinAPI calls; the import table is filled in randomly each time
- the entire critical code (for example, encryption) works on a stack-based virtual machine whose code is also obfuscated

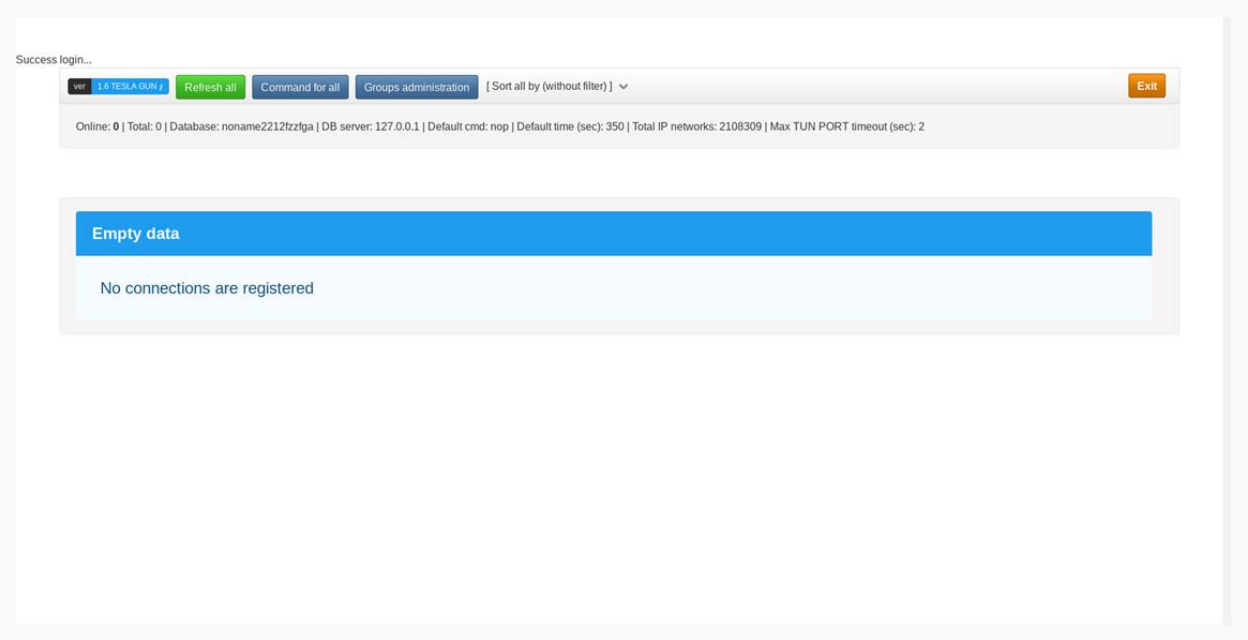
Threat name	Detection	Regions attacked	Related notifications
Servhelper backdoor	February 2019	Global	CP-2129

Based on their analysis, Group-IB specialists concluded that Servhelper backdoor, a tool that was used in Silence and TA505 attacks, may be sold on underground forums.

A post advertising the rent of HRDP-type malware was discovered. The poster was the user with the nickname leap. According to the post, the tool creates a hidden account on the victim computer and uses it in parallel with the main one. After infecting a device, the malware can launch and use browsers and legitimate programs on behalf of the user (with their cookie files, saved passwords, etc.). The program can also be used as a non-resident loader for other malware.

The C&C server is communicated with through socks5 backconnect. The tool is capable of bypassing UAC.

Group-IB's specialists contacted the seller to obtain additional information and were able to get test access to the tool.



Screenshot of the tool's admin panel.

Analysis of the sample revealed that it is Servhelper with a high degree of likelihood. This is evidenced by the following characteristics:

- Both tools have the same format of commands from the C&C server: command^argument
- leap's HRDP and Servhelper use an identical PowerShell script for infection. Both cases involve Base64 for encoding and Triple DES in CBC mode for encryption.
- Strings in HRDP and Servhelper are encrypted using the Vigenère cipher.
- Both tools are written in Delphi.

Threat name	Detection	Regions attacked	Related notifications
EcoXyz	September 2019	Latin America	CP-2064

On September 4, 2019, the Chilean CSIRT published a report on malicious activity against citizens and banks that involved the Proxy Changer technique and Chrome extensions. A malicious program was discovered that steals banking credentials of various financial organizations. The malicious campaign involved a fake Flash Player plugin update that tried to infect targeted computers. Group-IB specialists observed and analyzed the malware sample used in the September campaign. The malware is a JS script designed to install a PAC file and a malicious Google Chrome extension on infected devices. Both actions are aimed at redirecting all visits to Chilean banks' websites to phishing pages by configuring a proxy server. We analyzed this malware and named it EcoXyz in our Threat Intelligence system. It has been established that the following banks have been targeted:

- *santander*
- *officebanking*
- *bancochile*
- *scotiabankchile.cl*
- *bbva.cl*

- *scotiabankazul.cl*
- *bancofalabella.cl*
- *bice.cl*
- *bci.cl*
- *bancoestado.cl*
- *banco.itau.cl*
- *bancoripley.cl*
- *bancosecurity.cl*

All requests sent to an address that matches one of the substrings in this list will be redirected to threat actors' server.

Threat name	Detection	Regions attacked	Related notifications
Malware for brute forcing e-commerce and CMS platforms	October 2019	Global	CP-2111

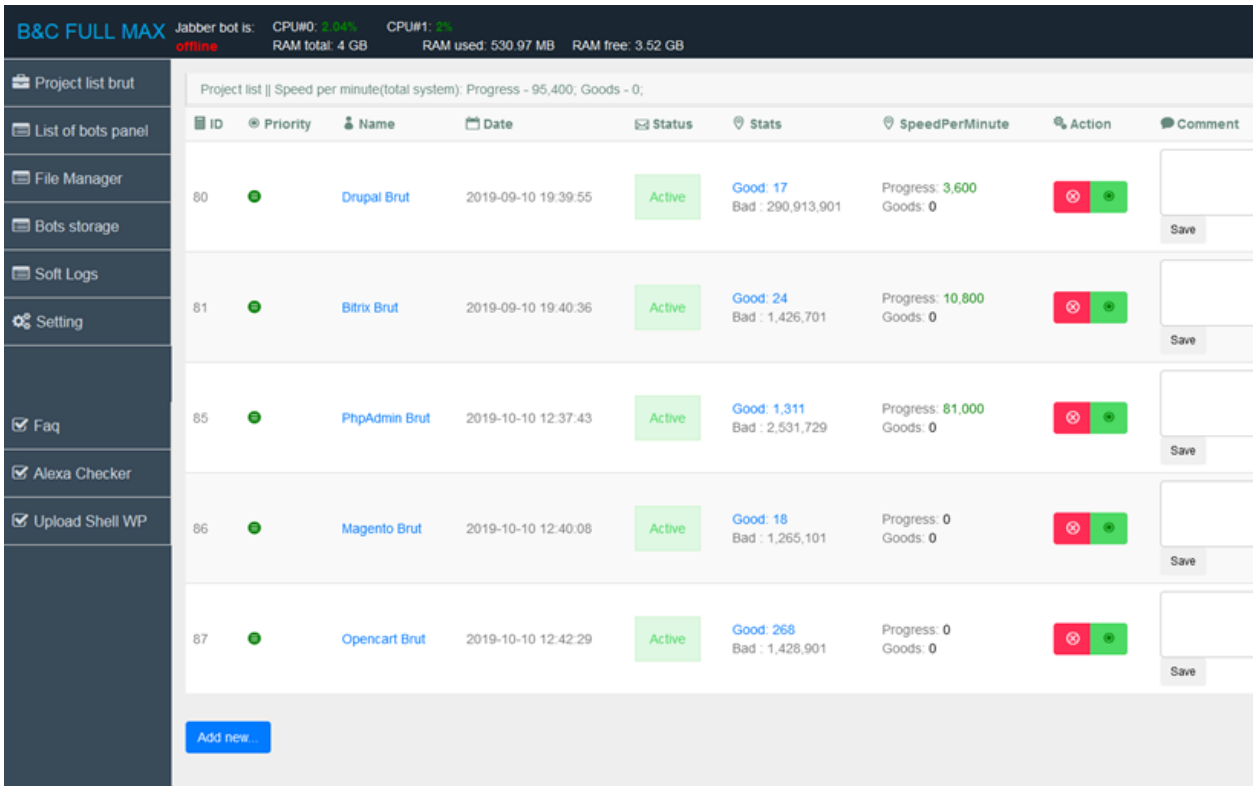
In October 2019, new malware for brute forcing the admin panels of various e-commerce and CMS platforms was put up for sale on an underground forum. The tool can also be used for brute forcing certain network services (SSH, FTP). The malware runs on various operating systems (Windows, Linux, OS for routers). The seller is a user named bruteguru.

The full list of accessible services:

Magento - Brute/Checker

- Wordpress - Brute/Checker/Autoupload shell
- Drupal - Brute/Checker
- Joomla - Brute/Checker
- Opencart - Brute/Checker
- Bitrix - Brute/Checker
- Cpanel - Brute/Checker
- WHM - Brute/Checker
- PhpMyAdmin - Brute/Checker
- Htpasswd - Brute/Checker
- Ftp - Brute/Checker
- Ssh - Brute
- Mysql - Brute
- Postgresql - Brute
- Woocommerce - Brute
- Adminfinder – Checker

In addition, the author says they will add RDP brute force in the near future.



Screenshot of the admin panel.

Threat name	Detection	Regions attacked	Related notifications
EternalBlue exploit–based loader	November 2019	Global	CP-2113

A user with the nickname ghostrider made a post on Exploit.in, an underground forum, about selling a loader that is based on the EternalBlue exploit. The exploit was used to spread the Wannacry and Petya ransomware in 2017.

The malware is an archive that contains about 100 files, most of which are Microsoft Visual Studio library files.

The author noted that scanning a computer using this exploit takes about 20 minutes. Following this, a file from a VPS is downloaded to the infected computer.

The threat actor mentioned that the exploit works on Windows XP, Vista, 7 and Windows Server 2008.

The EternalBlue exploit was published by the Shadow Brokers hacking group in April 2017. The exploit is aimed at exploiting a vulnerability in the Microsoft SMBv1 server. The exploitation of vulnerabilities CVE-2017-0143, CVE-2017-0144, CVE-2017-0145, CVE-2017-0146, CVE-2017-0147, and CVE-2017-0148 led to an epidemic with WannaCry and Petya ransomware in 2017. Microsoft issued patches that fixed the vulnerability in Windows, including for non-supported Windows XP, 7, and Windows Server 2003.

Threat name	Detection	Regions attacked	Related notifications
Hidden VNC (author: ScanHaven)	December 2019	Global	CP-2116

In November 2019, new private software for hidden remote desktop access, which runs on Windows (from XP to 10), was put up for rent on Exploit.in, an underground forum. The author is a user named ScanHaven.

According to the post, the software was written from scratch in C and NodeJS. It runs on Windows (from Windows XP to Windows 10) and works with Internet Explorer, Mozilla Firefox, and Google Chrome. The software comprises an .exe or .dll file, two JavaScript files (backconnect and orchestrator) and one HTML file (provides a list of available bots).

The software had the following features added later:

- support for multiple monitors
- capture of windows created using OpenGL or DirectX11-12
- support for Java applications

Price for one month is $1,800. The author says only 10 slots are available for rent.

Threat name	Detection	Regions attacked	Related notifications
RAT (author: Killogram)	December 2019	Global (except post-Soviet region)	CP-2118

The source code of a remote access Trojan was put up for sale on Exploit.in, an underground forum. The malware runs on Windows 7–10 and has the following functionality: keylogger, loader, remote access, etc.

The author said the source code of this RAT has various modules to ensure the following features:

- Hidden VNC (supports the most up-to-date Google Chrome version at the time of writing)
- Remote file manager
- Remote task manager (viewing and terminating processes)
- Viewing the screen
- Sending commands in a command line interpreter
- Working with the registry
- Working with startup
- Reverse proxy
- Loader
- Keylogger
- Bypassing UAC (for Windows 7–10, with the exception of the latest updates).

The malware is designed to be used on Windows and is a Visual Studio project with the code in C++.

The author noted that the Trojan needs improvement for further use, which means the malware will be updated.

Threat name	Detection	Regions attacked	Related notifications
TA505 group	2018	Global	CP-2127-1

Group-IB specialists studied the activities, infrastructure, and tools of the TA505 group, which sends out mass emails with malicious contents.

The following has been established:

- TA505 is one or several groups that send out mass malicious emails.
- TA505 delivers other group's malware as the payload.
- It is probable that TA505 also engages in initial infection to later sell access to third parties.

Tools used:

- Necurs botnet to send out documents
- Malicious .xls/.doc documents with macros
- TA505.Get2

Analysis revealed that TA505 delivered the following malware:

- FlawedAmmy
- FlawedAmmy.Downloader
- FlawedGrace
- SDBbot
- ServHelper
- Amadey
- Andromut
- Clop Ransomware
- Silence.MainModule

Evidence used for TA505 attribution:

- Use of a document with specific macros. The image shown to the user and the macros occasionally change.
- Use of a specific packer for the payload. The payload encryption method occasionally changes.
- Use of the Get2 loader.
- The domains used as the C&C servers for Get2 as well as domains that spread the malicious documents include substrings with the names of Microsoft, Dropbox, Google and other products. They also have overlaps with the Necurs botnet.

APT name	Regions attacked	Operation start
FIN6	Global	2018

In October 2019, specialists at TrendMicro reported about a credit card skimming attack by the Magecart group, which actively operated on 3,126 online shops.

The specialists' report says the attack started on September 7, 2019. All of the impacted online shops are hosted on the cloud platform of the e-commerce service provider Volusion, one of the top e-commerce platforms in the market.

It was found that malicious code was injected into a JavaScript library provided by Volusion to their client shops. The injected code loaded another JavaScript stored on a Google Storage service. The loaded script is almost a direct copy of a normal JavaScript library but has a credit card skimmer carefully integrated. When customers submit their payment information, the skimmer will copy and send the personal information and credit card details to an exfiltration server belonging to the attackers.

During their investigation, the specialists found that the attackers seemed more experienced and thoughtful than many other skimmer groups. They did not simply add their malicious code at the top or end of a script; instead, they carefully integrated the code into the original script to be part of the execution flow of the program. The code was also written as simply as possible, making it difficult to be identified in a big library. Furthermore, they registered the domain of their exfiltration server in a style similar to a legitimate Volusion domain.

The specialists established that the skimmer is an improved version of the previous skimmer used in the attacks on British Airways and Newegg. Both old and current skimmers are written with jQuery, serialize the stolen data, and use the jQuery.ajax function to POST data to a remote server. Based on the discovered data, the attack was linked to Magecart, which is believed to be FIN6.

In December 2019 it was revealed that FIN6 was behind the theft of credit card data in retail stores and financial organizations in the United States and Europe. The group used new malware to do it.

The threat actors usually carried out POS (point of sale) attacks by using devices that scan bank cards. The databases of financial organizations that use credit cards were also attacked.

Specialists at Cybereason reported an attack on their customers in October 2019; analysis revealed that the hackers continuously distributed viruses from August 2019.

FIN6 is a financially motivated hacking group active since 2014. The criminals' victims are mostly casinos, hotels, retail chains, etc. Information security specialists believe the hackers are based in Eastern Europe.

APT name	Regions attacked	Operation start
RevengeHotels	Brazil, Argentina, Bolivia, Chile, Costa Rica, France, Italy, Mexico, Portugal, Spain, Thailand, Turkey	2015

Cybersecurity experts discovered a malicious campaign that poses a risk to bank card data stored in the information systems of hotels, as well as data received from travel agencies. At least 20 brands were attacked in Brazil, Argentina, Bolivia, Chile, Costa Rica, France, Italy, Mexico, Portugal, Spain, Thailand, and Turkey.

Several hacker groups participated in this campaign, it was reported. Experts know about at least two groups, RevengeHotels and ProCC. The campaign has been active since at least 2015, but in 2019 the attacks significantly increased.

To collect data from the clipboard and printer spooler and capture screenshots, the threat actors use remote administration Trojans, which they distribute via malicious attachments (Word, Excel, PDF) in phishing emails. Some of them exploit CVE-2017-0199 loading it using VBS and PowerShell scripts and then installing customized versions of RevengeRAT, NjRAT, NanoCoreRAT, 888 RAT and other custom malware such as ProCC on victim machines.

Not only do the hackers use remote access to infected computers themselves, but they also sell it on underground forums. The threat actors also infect front desk machines in order to capture credentials from the hotel administration software; they can then steal credit card details too.

Threat name	Detection	Regions attacked
Gootkit	2014	Italy, Austria, Germany, USA

Gootkit is a banking Trojan that can record video, take screenshots, change web pages using web injects, redirect victims to phishing sites, install a keylogger, and block URLs.

Targets detected in Q4 2019:

Oberbank (AT)
Usbank
Credit Agricole (IT)
unipolbanca.it
credem.it
intesasanpaolo.com
relaxbanking.it
postbank.de
dkb.de
postbank.de
deutsche-bank.de
commerzbank.de
ing.at
bksbank-online.at
raiffeisen.at
suntrust.com
Chase Bank
HSBC Bank
Bank of Montreal
bancopopolare.it
ing.it
popso.it
poste.it

Threat name	Detection	Regions attacked
Trickbot	2016	US UK Germany Poland Japan

Trickbot is a banking Trojan that uses techniques similar to those of Dyre. It is distributed through email spam. Lately, however, it has often been distributed using Emotet.

Trickbot's new features include the ability to steal PIN codes and data from the accounts of major US mobile operators such as Sprint, T-Mobile, and Verizon Wireless. This was detected in August 2019. In this

fraud scheme, the threat actor first gains control over the SIM card and the number of their victim (as a rule, this is done by contacting the mobile operator and employing social engineering techniques, but other scenarios are possible too). As a result, the attacker takes control over their victim's phone number and all services it is linked to (including bank accounts, email, etc.), as well as onetime passwords, two-factor authentication codes, and so on. Trickbot intercepts traffic for mobile operator login pages and shows victims a modified login page where apart from regular data (phone number and password) the user is asked to enter their PIN code.

Analysis of detected samples showed that in Q4 2019 Trickbot attacks targeted the following banks (examples):

Capital One
Citi
Noris bank (DE)
BBT.com
Sparda (DE)
Wells Fargo
USBank
Centrum24 (PL)
BBVA
Chase
Halifax
Rakuten
Keiyobank
Mizunobank
Hokkokubank
Fukuokabank

Threat name	Detection	Regions attacked
Gozi (ISFB, Ursnif, Dreambot)	2007	Australia, New Zealand, Italy

In Q4 2019 we detected Gozi attacks in Australia, New Zealand, and Italy.

Examples of targeted banks in Australia and New Zealand:
ANZ
Bankwest
Bendigobank
Commonwealth
NAB
ING AU
Bankofmelbourne
BankSA
Stgeorge
Westpac
ASB

Australianmilitarybank
Adelaidebank

Targeted banks in Italy:

tecmarket.it
cbibanking.it
cim-italia.it
credem.it
fideuramonline.it
bcp.it
mps.it
sella.it
cabel.it
fmbcc.bcc.it
bancapassadore.it
bancobpm.it
finecobank.com
nowbankingcorporate.it
credit-agricole.it
brsspa.it
banking4you.it
nexi.it
ing.it
cariparma.it
bancagenerali.it
poste.it
hellobank.it
gruppocarige.it
chebanca.it
bancaeuro.it
icbpi.it
inbank.it
italy.db.com
bancaprossima.com
pec.it
vianova.it
popso.it
unipolbanca.it
chebanca.net
relaxbanking.it
tim.it
csebo.it
unicredit.it
ubibanca.com
bnl.it
cedacri.it

Threat name	Detection	Regions attacked
IcedID (aka Bokbot)	2017	US, Canada, UK

IcedID was first detected in late 2017. The malware can be used to steal financial information and launch targeted attacks. IcedID is mostly distributed using Emotet but also through phishing emails with a malicious macro that downloads and launches IcedID.

IcedID has a modular architecture and functionality comparable to Zeus, including web injects, data theft, and the ability to inject code into other processes. One of the bot's specific characteristics is its ability to deploy a proxy server on an infected machine and redirect all internet traffic using that server.

In addition to banks, IcedID has lately been attacking e-commerce businesses. In either case, the criminals' aim is to obtain bank card details: card number, CVV, expiration date, and the region where the victim is located.

The detected IcedID samples target banks in the US, Canada, and the UK, as well as e-commerce vendors.

In November 2019, specialists at Malwarebytes reported that they had detected campaigns, in which IcedID was distributed as hidden data in a .png file.

Known targets:

HSBC Bank
JPMorgan
Citibank
Bank of America
The Synovus Financial Corporation
Toronto-Dominion Bank (TD BANK)
Chase Bank
Charles Schwab Corporation
Fifth Third Bank (53 bank)
Post Oak Bank (US)
Halifax
Usbank
Unionbank (US)
USAA Bank
Canadian Imperial Bank of Commerce
Mandtbank

Threat name	Detection	Regions attacked	Related notifications
RTM	2015	Russia, Belarus, Kazakhstan, Ukraine, Azerbaijan	CP-2078 CP-2130

The program is written in Delphi and is a modular Trojan. Judging by its functionality, the Trojan targets remote banking services and payment systems. Its latest tracked sample searched for the following remote banking services on infected machines: BSS_PC, Faktura, HandyBank, QiwiCashier, Raiffeisen, RosBank, SberBank_BO, SberBank_Fiz, SberBank_PC, and VTB24.

The RTM group has a main panel and a separate Proxy panel showing banks they target specifically: all requests are sent to phishing servers where the traffic is proxied.

Since early 2019, mass emails that distribute the RTM Trojan have continued to be actively sent out. We detect such emails almost every day. The recipients are Russian-speaking legal entities.

It has also been established that RTM has lately been involved in attacks on legal entities in Belarus. The remote banking systems of the following banks have been targeted: Belarusbank, BPS-Sberbank, BelVEB, BSB Bank, Belgazprombank, Alfa-Bank, Belinvestbank, Idea Bank, Paritetbank, MTBank, StatusBank, Belagroprombank.

Group-IB specialists also studied an RTM-based botnet. The analysis revealed that at least 5,368 computers were infected with this Trojan. These were mainly computers in Russia (4,432), Ukraine (35), Belarus (745), and Kazakhstan (85). There were, however, some infected stations in Azerbaijan (12).

The malware's main targets are small and medium-sized businesses. However, there are also computers in the infrastructures of large businesses and government agencies.

Threat name	Detection	Regions attacked
Danabot	2018	Australia, Poland

The modular banking Trojan Danabot was first detected in the spring of 2018. It uses web injects and intercepts the victim's data. It has VNC, Sniffer, Stealer, TOR and RDPWrap modules.

New features were later added to it, namely, several layers of encryption for transferring data to the C&C server and a new loader component with an ability to load plugins along with the main module, which makes it an even greater threat.

In Q4 2019, we detected two types of Danabot samples: Australian and Polish. Among the targets are the following banks:

Australia and New Zealand Banking Group
Westpac
Bank of Melbourne
Bank of South Australia (BankSA)
St.George Bank
Commonwealth Bank of Australia
National Australia Bank
toyotabank.pl
bosbank24.pl
centrum24.pl
citibankonline.pl
credit-agricole.pl
e-skok.pl
e25.pl
db-pbc.pl
ibiznes24.pl
ipko.pl
gb24.pl
bnpparibas.pl
ingbank.pl
nestbank.pl
citidirect.com
neobank24.pl
getinbank.pl
ideabank.pl
sgb.pl
aliorbank
t-mobilebankowe.pl

Threat name	Detection	Regions attacked
Ramnit	2010	Japan

The Ramnit banking Trojan was first discovered in 2010. In 2015, the Ramnit botnet was taken down by a joint international operation coordinated by Europol. The Trojan's activity, however, did not stop and it continued to be used to compromise bank cards in North America and Europe up until the beginning of 2018. It was followed by a lull, but in Q3 2018, Ramnit resumed its activity. The threat actors focused on attacks against Japan and the United States, occasionally targeting European banks.

In June 2019, a threat actor with the nickname m0roz started selling the source code of this malware on an underground forum. According to their post, it is being sold only to one person. As at September 2019, it is unclear whether a copy of the malware has been sold: the seller is not replying to questions, but the forum topic has not been closed.

Known Ramnit targets:
Credit Saison
Idemitsu Credit Co.

Mitsubishi UFJ NICOS Co
Aeon Bank
Life Card Co.
Pocket Card Co.
Cedyna Financial Corporation
Epos Card Co.
Rakuten
Sumimoto Mitsui Card Co.

Attacks on ATMs and POS terminals

Threat name	Detection	Regions attacked	Related notifications
Bank card compromise affecting customers of restaurant chains Moe's Southwest Grill, Schlotzsky's, and McAlister's Deli	November 2019	USA	CP-2102

On November 22, 2019, the owner of Joker's Stash, made a post on Omerta, an underground resource, about the appearance of a new database of compromised bank card dumps called NEW WORLD ORDER BREACH (NWO BREACH) on Joker's Stash. According to the owner of Joker's Stash, the new database will contain four million cards. On November 22, some of the data was made available for purchase (723 thousand cards from the database). Analysis revealed that the most likely source of the compromise are POS terminals. Three companies, whose devices are thought to have been compromised, were identified: Moe's Southwest Grill, Schlotzsky's, and McAlister's Deli. Earlier, on October 2, 2019, Moe's Southwest Grill, Schlotzsky's, and McAlister's Deli posted a notice about the compromise of the payment systems in some of their restaurants on their official websites.

As at December 10, 2019, the owner of the card shop continues to upload cards from this database. The number of uploaded cards reached 932,000 and continues to grow.

APT name	Regions attacked	Operation start
FIN8	North America	2019

Specialists at Visa warn that fuel stations in North America have increasingly been falling victim to attacks involving POS Trojans. For instance, two such cases were reported in November and December 2019 and the company's security team investigated a total of at least five such incidents in 2019.

The alert says that in one of the detected incidents unknown threat actors compromised their target through a phishing email that helped them infect one of the systems in the network with a remote access Trojan (RAT).

This gave them direct access to the network and enabled them to obtain credentials with enough permissions to move laterally in the network and compromise the POS environment.

Finally, the attackers deployed a Random Access Memory (RAM) scraper to harvest payment card data.

Visa's Payment Fraud Disruption (PFD) team says that the second and third incidents involved malicious tools and TTPs associated with the financially motivated FIN8 threat group.

In the second attack, the threat actors employed an unknown vector to gain access to the network and infect the POS environment with a RAM scraper payload intended for magnetic stripe transactions. The malware used in the attack also created a temporary output file, "wmsetup.tmp," which was used to house the scraped payment data.

In the third incident, PFD analyzed malware recovered from the network of a compromised North American hospitality merchant and determined that the compromise was likely the result of an operation conducted by FIN8.

The attack involved FIN8-attributed malware as well as new malware based on the RM3 variant of the Ursnif (aka Gozi/Gozi-ISFB) modular banking Trojan, which is usually delivered through phishing attacks and exploit kits.

FIN8 is a financially motivated group known for launching specialized campaigns to steal payment card data. The group targets retailers, restaurants, and hospitality businesses.

Threat name	Detection	Regions attacked	Related notifications
ATM Trojan for Diebold Nixdorf ATMs	October 2019	Global	CP-2048

In August 2019, new malware for Diebold Nixdorf ATMs was put up for sale on an underground forum. The tool exploits an RCE vulnerability when a Raspberry Pi device is connected to the Ethernet or USB ports of Opteva ATM models. An infection would most likely result in the dispensing of all cash from ATM cassettes (ATM jackpotting).

Infection can be achieved using:

- Raspberry Pi 3 Model B+ connected to an ATM's Ethernet port.
- Raspberry Pi Zero W connected to a USB port.

In the case of infection through a USB port, Raspberry emulates Ethernet and works as a Wi-Fi dongle. An infected ATM dispenses money after a shellcode is executed. The seller also mentioned that the malware can be adjusted for a buyer's needs (for example, addition of features such as RAT, VNC, and code execution through DLL).

The seller is a user named "Fear." In 2016, they sold a private banking Trojan called Midas bot (also known as Jupiter).

Threat name	Detection	Regions attacked
Compromise of Catch Hospitality Group	November 2019	USA

In November 2019, Catch Hospitality Group, a chain of US restaurants, which includes Catch NYC, Catch Rooftop and Catch Steak, announced on their website that from March through October some of their POS terminals were compromised by malware.

The malware was deactivated during investigation.

Threat name	Detection	Regions attacked
Compromise of Krystal burgers	November 2019	USA

Another restaurant chain, whose restaurants are mainly located in the south of the United States, announced that their payment processing system was compromised from July through September 2019. A POS Trojan was most likely used.

State-sponsored APTs

APT name	Regions attacked	Operation start
Lazarus	India, Global	January 2019

In September 2019, Kaspersky Lab published a report, in which they described a previously unknown malicious tool called Dtrack. Using YARA rules developed to detect this malware, Group-IB specialists detected and analyzed the DTrack payload.

We conducted further analysis and discovered that someone from India uploaded an archive to VirusTotal that contained this malware and data it had collected. Our analysis revealed that the logs contained data from a compromised machine running Windows.

All files in the archive were compiled at different times, but the main file with the compromised data is dated January 30, 2019. The archive was uploaded to VirusTotal on September 2019. This suggests that the hackers remained unnoticed in the victim's network for a long time.

Group-IB specialists concluded that Lazarus compromised an employee of the Nuclear Power Corporation of India Limited (NPCIL). The hackers allegedly gained access to the data of a senior manager, which can be used by Lazarus to not only manage the flow of money but reach the company's most critical infrastructure.

We later found a file that we detect as Dtrack.Stealer. Analysis revealed that the attack against NPCIL, which we wrote about earlier, developed further and, as a result, the Kudankulam Nuclear Power Plant, which is situated in the south of the state of Tamil Nadu, was compromisedl. On October 19, 2019, the power plant's second power unit was shut down. We believe that these events may be linked.

On October 25, 2019, a suspicious ELF file was discovered. Detailed analysis revealed that it is a fully functional, covert and RAT program targeting both Windows and Linux platforms.

Dacls is a new type of remote-control software with versions both for Windows and Linux with a common C&C protocol. They were called Win32.Dacls and Linux.Dacls respectively. The software's functions are modular, the C&C protocol uses TLS and RC4 double-layer encryption, the configuration file uses AES encryption and supports C&C instruction dynamic update. The Win32.Dacls plug-in module is dynamically loaded through a remote URL, and the Linux version of the plug-in is compiled directly in the Bot program. It was established that there are six connectable modules for Linux: command execution, file management, process management, test network access, C&C connection agent, and network scanning module. The analysis revealed similarities with previous Lazarus attacks.

Lazarus (also known as Dark Seoul Gang, HIDDEN COBRA, Guardians of Peace) is a cybercriminal group active since 2007. Specialists have established that the group's members are from North Korea.

APT name	Regions attacked	Operation start
Calypso	India, Brazil, Kazakhstan, Russia, Thailand, Turkey	2016

In October 2019, the activity a Chinese hacking group called Calypso, which targets government agencies, was discovered.

In one attack, the group used the PlugX malware, which has traditionally been used by many APTs of Chinese origin, and the Byeby Trojan, which was used in the SongXY (NetTravaler) malicious campaign in

2017. In addition, in individual attacks the threat actors mistakenly disclosed their real IP addresses, which belonged to Chinese providers.

The threat actors hacked and placed a special program on the network perimeter. They used the program to gain access to the internal networks of compromised organizations. Investigation revealed that the threat group performed lateral movement either by exploiting the remote code execution vulnerability MS17-010 (the notorious EternalBlue exploit is intended for this particular bug, which is also identified as CVE-2017-0144), or by using stolen credentials.

APT name	Regions attacked	Operation start
Patchwork	Pakistan	July 2018

The Patchwork hacker group continued their attacks against Pakistan. The threat actors used complex phishing, which involved a malicious Office document of a legitimate article published on October 7, 2019 by Samaa.tv, one of the most important media outlets in Pakistan. The article used in this campaign is related to the current rise in geopolitical tensions between India and Pakistan over Kashmir.

The document called “India's_Extremisms_Under_Mobi.docx” was written in English, which is an official language for both countries. The startling headline selected in the campaign tries to attract the attention and interest of the Pakistani and Indian people through social fear.

When the document is opened, the MSOffice Word editor process is constantly suspended and acts in an unstable way. Analysis of the document revealed that it contains a file called “image1.eps,” which corresponds to a Flash element of the document that exploits an Adobe Flash vulnerability known as CVE-2017-0261.

The exploit executed by the document contains a shellcode that dumps three executable files—two of them related to VMWare, and one named “MSBuild.exe”—into the folder C:\ProgramData\Microsoft\DeviceSync. After creating these files, the shellcode runs a binary named “VMWareCplLauncher.exe.”

The executable “VMWareCplLauncher.exe” is a signed binary from VMWare and the DLL is also a legitimate part of VMWare, which is automatically loaded by the executable and has been modified to create two scheduled tasks.

After a minute, the task programmed with the name “Windows Update…” launches the “MSBuild.exe” binary, which consists of a first stage Trojan with a multitude of capabilities described below. The Trojan communicates with the C&C server through the HTTP protocol and constantly sends information collected from the victim computer to it.

The response of the server is checked in its logic in search of one of the following numbers “4, 5, 8, 13, 23, 33.” These numbers correspond to different commands related to the downloading and execution of other binaries, keyboard monitoring, sending of screenshots to the C&C server, or theft of files with the following extensions: .doc, .docx, .pdf, .ppt, .pptx, .jpg, .jpeg, .png, .rtf, .txt, .7z, .rar, .zip, .docm, .msg, .wps, .xps, .pptm.

The Patchwork group (also known as Dropping Elephant, Chinastrats, APT-C-09, Monsoon, and Quilted Tiger) has been active since at least 2015 and has been attacking organizations in industries connected with diplomatic missions and governmental entities for the purposes of espionage and information theft.

APT name	Regions attacked	Operation start
APT37	South Korea, China	October 2018

From late August until mid-September 2019, the APT37 hacker group (North Korea) carried out a number of phishing attacks against traders from China and South Korea, it was reported.

Even though no emails were detected, it is believed that the attack was conducted via email. This time the decoy document was a compressed .rar file. The result of its decompression is an executable file, which is a loader that downloads a malicious module from artmuseums.or.kr.

Once decrypted, the downloaded .jpg file is an actual RAT and the path to the file is C:\Users\Administrator\AppData\Roaming\Microsoft\Windows\svchost.exe.

The RAT collects information about the victim computer and executes commands, which are transferred from the C&C server. The collected data is compressed and sent back to the C&C server.

APT37 hackers carried out a stealthy mobile APT attack. The hacker group also distributed a malicious app (APK) via a site disguised as a fundraising service for supporting North Korean defectors.

The website is built on the WordPress platform; the domain was created on August 23, 2019 and updated on October 22.

Snapshots in the archive displayed from September 11 to October on the timeline indicate that it is a charity site that supports North Korean defectors and the Android app installation link (Google Play) was added in October.

Cybersecurity specialists named the operation Dragon Messenger based on several interesting factors found in the campaign, such as a malicious application that collects data via the DragonTask path and an attack performed through what was disguised as a secure messenger.

The website became known to the public through comments written by the ID “David Kim,” who says they are the administrator of the website.

The malware makes it possible to steal SMS and phone address books, eavesdrop on phone conversations, and leak KakaoTalk messages appearing in the notification window.

APT37 (also known as Group123, Reaper, ScarCruft, Geumseong121, and Red Eyes) is a North Korean cyberespionage group active since at least 2012. The group primarily targets South Korea, but also Japan, Vietnam, Russia, Nepal, China, India, Romania, Kuwait, and other regions.

APT name	Regions attacked	Operation start
APT41	Global	2019

The Chinese threat group Winnti developed new malware designed to alter Microsoft SQL Server (MSSQL) databases and create a backdoor. As an added benefit, the backdoor also hides user sessions inside the database's connection logs every time the "magic password" is used, helping hackers remain undetected.

Named "skip-2.0," the backdoor modifies MSSQL functions that handle authentication. Considering that administrative privileges are required for installing the hooks, the threat actors deploy the backdoor only after the targets have been compromised through other methods. The tool is essentially used to achieve greater persistence and stealthiness.

The idea of skip-2.0 is to create a "magic password." If the "magic password" is entered inside any user authentication session, the user is automatically granted access, while normal logging and audit functions are prevented from executing, effectively creating a ghost session inside the server.

According to cybersecurity experts, skip-2.0 only works with MSSQL v12 and v11 servers. Even though MSSQL Server 12 was released as early as 2014, it is the most commonly used version according to Censys.

The Chinese state-sponsored threat group APT41 (also known as BARIUM, Winnti, LEAD, Axiom, and Group 72) has been active since 2012. The group's espionage campaigns have targeted healthcare, telecommunications and high-tech sectors and have historically involved intellectual property theft. The group's attacks have targeted the gaming industry, including the manipulation of virtual currencies and attempted deployment of ransomware.

APT name	Regions attacked	Operation start
Kimsuky	South Korea, USA, Vietnam	July 2019

During Q4 2019, the Kimsuky group carried out phishing campaigns twice, it was observed.

Both attacks involved .hwp attachments as decoys. In the first case, the document was called "KINU 전문가 자문 요청사항" (which translates as KINU Expert Advisory Request). It was a questionnaire on the US–Korea alliance.

The second case involved a file called "베트남 녹지원 상춘재 행사 견적서.hwp" (which translates as Quotations from a meeting with Vietnamese representatives in Sangchunjae). Since the spear-phishing campaign referred to a meeting between Korean and Vietnamese representatives in the Blue House, experts called the campaign Operation Blue Estimate.

The first extension is .hwp, but the document has a double extension with a lot of spaces and actually has the .exe format.

The document has a "BINARY" resource inside and contains a data set in Korean in the "103" and "104" areas respectively.

The "103" data contains a normal .hwp file, while the "104" data contains the final malicious 32-bit DLL file.

The malicious file performs C&C communication with a specific domestic website and may be exposed to additional threats according to the attacker's command.

Usually, in such a case, the attacker secretly installs additional customized malicious files and attempts to remotely control or steal confidential information.

Kimsuky (also known as Velvet Chollima and Thallium) is a hacker group believed to be based in North Korea. The group has been actively attacking entities on the South Korean territory since 2010, but has lately been expanding the geography of their attacks.

APT name	Regions attacked	Operation start
APT5	Global	January 2019

In September 2019 it was reported that the Chinese threat actors targeted enterprise VPN servers from Fortinet and Pulse Secure after details about security flaws in both products became public in August 2019.

Starting in late August, a subgroup of the larger APT5 umbrella group set up an infrastructure, through which they started conducting internet scans to search for Fortinet and Pulse Secure VPN servers. The hackers later attempted to exploit two vulnerabilities in the two VPN server products. Both vulnerabilities (CVE-2018-13379 for Fortinet and CVE-2019-11510 for Pulse Secure) are so-called "pre-auth file reads," which allow an attacker to retrieve files from the VPN server without needing to authenticate.

Both the Fortinet and Pulse Secure vulnerabilities were discovered in early 2019 by security researchers at a company called Devcore. The vendors were informed about the issues in March and the vulnerabilities were patched.

In October 2019, the UK's National Cybersecurity Center (NCSC) warned organizations that Palo's GlobalProtect portal and GlobalProtect Gateway interface were also being attacked by hackers. These attacks are still ongoing and target not only British but also international organizations, such as government, military, academia, business and healthcare.

List of vulnerabilities exploited:

Pulse Connect Secure:

- CVE-2019-11510: Pre-auth arbitrary file reading
- CVE-2019-11539: Post-auth command injection

Fortinet:

- CVE-2018-13379: Pre-auth arbitrary file reading
- CVE-2018-13382: Allows an unauthenticated attacker to change the password of an SSL VPN web portal user.
- CVE-2018-13383: Post-auth heap overflow. This allows an attacker to gain a shell running on the router.

Palo Alto:

- CVE-2019-1579: Palo Alto Networks GlobalProtect Portal

APT5 (also known as Manganese) has been active since 2007. Researchers say the hackers appear to be a large threat group that consists of several subgroups, often with distinct tactics and infrastructure. The threat actors are believed to be sponsored by the Chinese government. APT5 has targeted or breached organizations across multiple industries, but its focus appears to be on telecommunications and technology companies, especially information about satellite communications.

APT name	Regions attacked	Operation start
Mustang Panda	South-East Asia, Germany, Mongolia, Myanmar, Pakistan, Vietnam, Syria, Palestine, Lebanon	November 2018

Cybersecurity researchers at Anomali identified 15 documents created and utilized by Mustang Panda: from malicious files purporting to be coming from the government of Vietnam to fake documents from religious organizations.

The Chinese hackers launched a campaign against international minority groups, non-governmental organizations, and governments, distributing malicious documents via email. The research study says the malicious campaign has been ongoing since November 2018.

The observed Tactics, Techniques, and Procedures (TTP) are:

- Use of a .zip file that contains an .lnk (Windows Shortcut) file
- Utilization of double extension trick (sample.doc.lnk) to convince users to open the file
- HTA (HTML Application) with VBScript embedded in the .lnk file
- VBScript drops payloads and opens a decoy document or PDF to the user
- Use of PlugX and Cobalt Strike payloads

Mustang Panda is a Chinese threat group active since at least April 2017.

APT name	Regions attacked	Operation start
Charming Kitten	USA	October 2019

In a 30-day period, experts at Microsoft observed hackers making more than 2,700 attempts to identify consumer email accounts belonging to specific Microsoft customers and then attacking 241 of those accounts. Four accounts were compromised, as a result of these attempts.

The hacker's main goal was to break into US President Donald Trump's re-election campaign. The hacker's actions targeted accounts associated with current and former US government officials, journalists covering global politics, and prominent Iranians living outside Iran.

The study says that while the attacks "were not technically sophisticated," the threat actors had a significant amount of personal information about the individuals they targeted in their attacks. This effort led Microsoft to conclude that the Charming Kitten hackers are highly motivated and willing to invest significant time to gather information about their potential targets and prepare attacks.

The Iranian threat group Charming Kitten has been engaging in attacks since at least 2013, it has been observed. The group focuses on individuals of interest to Iran who work in the fields of academic research, human rights, and media, with most victims located in Iran, the United States, Israel, and the UK. The hackers usually try to gain access to private email and Facebook accounts and sometimes establishe a foothold on victim computers as a secondary objective.

APT name	Regions attacked	Operation start
PKPLUG	South-East Asia	November 2013

Unit42 released a report about PKPLUG, a moniker they created for one or several groups that use the same tools and have the same tasking. The name comes from the tactic of delivering PlugX malware inside ZIP archive files as part of a DLL side-loading package. The ZIP file format contains the ASCII magic-bytes "PK" in its header, hence PKPLUG.

The specialists discovered additional, mostly custom malware families being used by PKPLUG beyond that of just PlugX. The additional payloads include HenBox, an Android app, and Farseer, a Windows backdoor. The attackers also use the 9002 Trojan, which is believed to be shared among a small subset of attack groups. Other publicly available malware seen in relation to PKPLUG activity includes Poison Ivy and Zupdax.

The group's victims are mainly located in and around South-East Asia, particularly Myanmar, Taiwan, Vietnam, and Indonesia, and likely also in various other areas in Asia, such as Tibet, Xinjiang, and Mongolia. Based on targeting, content in some of the malware, and ties to infrastructure previously documented publicly as being linked to Chinese nation-state adversaries, it was concluded that PKPLUG has similar origins.

APT name	Regions attacked	Operation start
APT29	Europe	September 2013

In October 2019, cybersecurity specialists reported about a campaign called Ghost by APT29, which started in 2013 and continued until at least June 2019.

Identified victims include ministries of foreign affairs in at least three different countries in Europe; two of them had been attacked by the group earlier. This time, the hackers used new malware, namely PolyglotDuke, RegDuke, and FatDuke, as well as a previously documented program, MiniDuke. The threat actors encoded the addresses of their C&C servers in posts on online services.

Ghost timeline:

- September 2013: First known compilation timestamp of PolyglotDuke
- July 2014: Post on Reddit containing an encoded C&C URL
- September 2016: First known deployment in the wild of a FatDuke sample
- August 2017: First known deployment in the wild of a RegDuke sample
- October 2018: Last Twitter account registered by the Dukes
- June 2019: Latest known FatDuke sample deployed in the wild

Specialists were not able to identify the compromise vector. The group may have either sent out a malicious document via email or used credentials compromised earlier.

PolyglotDuke is used to download the MiniDuke backdoor. The downloader uses charsets from different languages to encode C&C addresses (hence the name). The addresses are transferred using Twitter. The downloader has 32- and 64-bit versions.

RegDuke is used when the attackers lose control of other malware on the victim's machine. It is composed of a loader and a payload, which are written in .NET. The payload downloaded by RegDuke is a backdoor that resides in memory only and that uses Dropbox as its C&C server. As a result, it drops the MiniDuke backdoor or the Process Explorer utility, specialists discovered.

MiniDuke acts as a second-stage backdoor. It implements multiple commands: uploading or downloading files, creating processes, getting system information, getting the list of local drives, reading and writing in the named pipe, and starting and stopping the proxy feature.

The FatDuke backdoor is deployed on the machines the threat actors are most interested in. The backdoor was named like that because the size of one of the detected samples was 13 MB. FatDuke can be controlled remotely by the attackers using a custom C&C protocol over HTTP or using named pipes on the local network. In order to look legitimate, the threat actors register variants of existing domains and redirect the homepage of their C&C server to the homepage of the real domain. In all of the cases the group used several C&C servers per target, but these servers do not overlap across the victims.

During the research into Operation Ghost, a previously unknown backdoor called LiteDuke was found on some machines compromised by MiniDuke. This backdoor was used in 2014–2015. It was dubbed LiteDuke because it uses SQLite to store information such as its configuration. The backdoor supports multiple commands, the main ones being: uploading or downloading files, securely deleting files, updating the database, create processes, getting system information, and terminating itself. Communication with the C&C is established through HTTP. The researchers believe that the C&C servers were compromised domains.

APT29 is a Russian-speaking threat group active since 2008. The threat actors mostly attack government and government-related organizations (ministries, research centers, universities) in Western Europe, and less so in the post-Soviet space, Turkey, Georgia, Asia, Africa, and the Middle East.

APT name	Regions attacked	Operation start
Higaisa	North Korea, China, Japan, Nepal, Singapore, Russia, Poland, Switzerland	2016

In November 2019, specialists at Tencent reported about a recently discovered APT group called Higaisa. The group started its activities as early as 2016 and carries out attacks using phishing emails with an executable file within, which is usually disguised as a legitimate installer or an image/document. Important news or congratulatory texts are usually used as decoys. The following tools employed by the group in their attacks were discovered:

- modified version of the Gh0st RAT
- keylogger
- malware for stealing Outlook passwords
- Android Trojans (can create screenshots; obtain GPS location information, SMS, and the address book; recording calls; and download and upload files).

On February 19, 2019 one of the mail-outs, which was related to the Korean New Year, took place. It was sent out from the address china*@126.com and targeted individuals from North Korea. The email contains congratulations on the Korean New Year and has an archive attachment, "정월 대보름날 즐겁게 보내 세요.zip," with an executable file within. Its execution results in a loader being downloaded, which receives two malicious files from the C&C server. The first one is a remote access Trojan based on the

open-source Gh0st RAT. The second file is used to collect information about the victim (system information, list of processes, list of shared resources, and file lists), which is then sent to the attackers' server in encrypted form.

Higaisa is an APT group based in South Korea. It has been active since at least 2016. Their attacks mostly target organizations whose activities are related to North Korea (governments, human rights societies, trade organizations). In addition, the group's victims have been identified in China, Japan, Nepal, Singapore, Russia, Poland, and Switzerland. The threat actors have overlaps in TTPs with the DarkHotel group but it has not been confirmed that they are linked.

APT name	Regions attacked	Operation start
Turla	Russia, Belarus, Middle East	January 2018

In June 2019, Symantec specialists published information about an attack conducted by Turla in 2018. The attack targeted an organization in the Middle East, which was compromised in 2017 by the OilRig group.

Turla's first activity is dated January 11, 2018, when the threat actors' task scheduler was dropped on to a victim computer. The next day, a custom variant of Mimikatz—which had only been observed being used by Turla—was downloaded from the server of the OilRig group to the same computer and packed with a custom packer. Turla also compromised two further computers on the victim's network, but with no evidence that OilRig infrastructure was used in these attacks. It is known that the Neptun malware was installed on the machines.

Turla's intrusions in the victim's network continued during 2018. On September 5, 2018, a similar Mimikatz variant was dropped by the Neptun backdoor to a computer in the victim's network. At around the same time, another malicious program installed in the network communicated with known Turla C&C servers. A legitimate system administration tool called IntelliAdmin was dropped on computers that had not been affected by the OilRig infection. This tool is known to have been used earlier by OilRig.

In addition to the above-mentioned attack, in October 2019 information about a Turla campaign was published, which the group carried out from April to August 2019 using a new tool called Reductor. Targets were identified in Russia and Belarus. The threat actors used two infection schemes for Reductor:

- by using infected popular software installers with 32- and 64-bit versions of Reductor included
- by using an additional malicious program called COMpfun, which receives a command to download additional modules from the C&C server and downloads Reductor's dropper as a result

It was found that the malicious installers (in the first scenario) were downloaded from warez websites. Research revealed that the original installers on the websites were not infected, however. This led to a suggestion that the threat actors have the ability to replace legitimate installers with infected ones on the fly. In addition to typical features such as uploading, downloading, and executing files, Reductor's developers added a feature to manipulate digital certificates and mark outbound TLS traffic with unique host-related identifiers. To communicate with the C&C server, Reductor sends HTTP POST queries to the addresses listed in its configuration and receives a command in response.

Apart from this campaign, specialists discovered malware called Tunnus, which is attributed to Turla with some degree of confidence. Tunnus is a .NET-based backdoor with an ability to run commands or perform file actions on an infected system and send the results to its C&C servers. The C&C infrastructure has been built based on compromised sites. Tunnus was used from at least March 2018 to August 2019.

Turla is a Russian-speaking cybercriminal group believed to have been active since 2007. The main goal of Turla's attacks is stealing information from diplomatic, government, military, educational, research and pharmaceutical organizations.

APT name	Regions attacked	Operation start
Potentially APT28	Kazakhstan	June 2019

In October 2019, a document called "gorodpavlodar.doc" was discovered. The document was emailed to people working in a mining corporation with operations located in Kazakhstan. The email was sent from the address pavlodar.news@bk.ru purporting to be from the "OFFICIAL RESOURCE OF THE CITY OF PAVLODAR." The malware used in the attack has similarities with the Zebrocy Trojan. In addition, Kazakhstan has historically been targeted by APT28. This may suggest that APT28 is behind the attack.

The attachment contained text written in Russian. It also prompts the recipient to enable a macro to view the "protected" document. Enabling the macro creates two files (.doc and .exe) and deletes the initial document. The created .doc file, which also contains a macro, is then opened and executes the second created file (executable). To maintain persistence, the registry is modified.

Communication with the C&C server is established through the HTTP protocol; information about the victim machine is sent first.

APT28 is a Russian-speaking cybercriminal group active since 2004. Most of the group's attacks have targeted political and military organizations, and, to a lesser extent, media outlets and sports organizations.

APT name	Regions attacked	Operation start
Operation WizardOpium	Global	2019

In November 2019, a campaign called WizardOpium was discovered. The campaign has not been definitively attributed to any APT group, but it has similarities with the DarkHotel group.

Specialists detected exploits for zero-day vulnerabilities in the campaign:

- Chrome 0-day CVE-2019-13720
- Windows 0-day CVE-2019-1458

To exploit CVE-2019-13720, the following tactic was used. The threat actors carried out a watering hole attack and injected malicious JavaScript code into the main page of a Korean news website. The script loads another script from a remote site. The downloaded script checks if the vulnerability can be exploited on the victim's system. If the browser checks out, the script starts performing a number of requests to the attacker-controlled server. The first request is designed to obtain information: how many chunks of the actual exploit code should be downloaded from the server, a URL to an image file that embeds a key for the final payload and RC4 key to decrypt these chunks of the exploit's code. After downloading all the chunks, the RC4 script decrypts and concatenates all the parts together into a new JavaScript code containing the full browser exploit. The vulnerability is use-after-free and the exploit manipulates the memory and makes it possible to read and write data on the victim's device. As a result, a shellcode is executed, which decrypts the final payload. After decryption, the payload is dropped as an .exe and executed. The next stages are located on the C&C server in folders with the victim computer names.

This exploit (CVE-2019-13720) was used together with another zero-day exploit (CVE-2019-1458). Exploiting the vulnerability becomes possible when the Win32k.sys component fails to properly handle objects in memory. An attacker who successfully exploited this vulnerability could escalate privileges in the system and run arbitrary code in kernel mode, which will allow them to install programs; view, change, or delete data; or create new accounts with full user rights.

APT name	Regions attacked	Operation start
OceanLotus	Vietnam, China, Cambodia	March 2019

On December 6, 2019, br.de, a news resource, reported that the computer networks of BMW and Hyundai had been compromised. The article says the OceanLotus group hackers are behind the attack. The group downloaded a tool called Cobalt Strike on a computer in BMW's network. The authors of the article say the threat actors were able to persist in the system over the course of several months. Unfortunately, BMW did not provide information for more accurate attribution of this attack.

However, we discovered a suspicious IP address, 103.27.203[.]221, which the following domains pointed to in April and March 2019:

- bmwthailand[.]org
- huyndai-auto[.]com
- bmw-corp[.]net

Interestingly, on April 2, 2019, bmwthailand[.]org had the address 188.166.203[.]57. This address hosted gdtechnical[.]com, a domain OceanLotus used.

On December 12, 2019, Tencent researchers published a report on the activities of the OceanLotus group in the second half of 2019. The researchers say the threat actors show a keen interest regarding the current political situation in China. In addition, the threat actors sent out emails with the subjects: "Definitive Report on the Submission of Materials for Business Performance Assessment Targets for 2019," "Latest Notifications and Updates for Organizational Cadres and Four Offices," "Instructions on the Implementation Plan for Increasing Wages in the Second Half of 2019 (Pending Review)," "2019 Standard Cadre Training Course Notice," and so on.

During these attacks the threat actors used techniques such as:

- Dll Side-Loading
- .LNK
- CVE-2018-20250
- .EXE
- .CHM
- Documents with malicious macros

The threat actors' end goal was to load payloads such as Denis, Cobalt Strike and, in some cases, Gh0st. After successful penetration, the attackers start scanning the local network to spread to other devices. In some cases, the group creates scheduled tasks through PowerShell to download additional tools.

In about mid-2019, the group started distributing three malicious applications to infect Android phones; one of the apps was downloaded more than 5,000 times.

It was found that the campaign involved the following malware disguised as system utilities:

- OpenGL ES Updater
- Ad Blocking Program
- Browser Cleaner

The threat actors deliberately created open GitHub repositories to avoid suspicion. To give the appearance of a legitimate application, they left email addresses to answer questions from users and created privacy policies. The malicious module was AES-encrypted.

OceanLotus, also known as APT32, APT-C-00, SeaLotus, Sinh Tử Lệnh, Cobalt Kitty, and SectorF01, has been active since late 2009 and is believed to be based in Vietnam. The group attacked Vietnamese bloggers and dissidents and launched targeted attacks on industrial and government entities in Vietnam, Cambodia, China, Laos, the Philippines, Germany, and the United States. Apart from phishing emails, OceanLotus carries out watering hole attacks.

APT name	Regions attacked	Operation start
OilRig	Middle East	Fall 2018

According to IBM, ZeroCleare (so named because of the program database (PDB) pathname of its binary file) was involved in a recently spotted APT attack on an oil and gas company, in which it compromised a machine via a vulnerable driver. ZeroCleare then pivoted to spread to other devices in the network for a further destructive attack. While the researchers say the exact number of organizations that were impacted is unknown, at least 1,400 hosts were affected by ZeroCleare.

The attack most likely started in the fall of 2018 with reconnaissance scanning from various low-cost/free VPN providers and gaining access to one of the accounts that was later involved in the attack. During the summer of 2019, the attackers used a password spray from a system on the local network to gain access to additional accounts, install ASPX web shells, and gain domain administration privileges.

Analysis showed that ZeroCleare shares certain characteristics with the infamous Shamoon malware in that it overwrites the master boot record (MBR) and disk partitions on Windows-based machines, using a legitimate driver, EldoS RawDisk. This renders infected machines inoperable.

To gain access to the device's core, ZeroCleare used a Microsoft-signed, vulnerable VBoxDrv driver, and malicious PowerShell/Batch scripts to bypass Windows controls.

- The analyzed PowerShell and batch scripts were designed to spread and execute the ZeroCleare malware across the domain.
- The main PowerShell script, ClientUpdate.ps1, spreads itself to Domain Controllers (DC), and then from those severs further in the network. It uses the Active Directory PowerShell module Get-ADComputer cmdlet to identify lists of target devices to copy and execute the malware on.
- The Batch scripts support spreading the malware but work in a more simplistic manner using premade text files that contain hostnames to infect, rather than generating the lists themselves.
- The ZeroCleare wiper's executable itself, delivered in a file named "ClientUpdate.exe," ran with a legitimate license key for EldoS RawDisk driver. ZeroCleare is part of the final stage of the overall attack. It is designed to deploy two different ways adapted to 32-bit and 64-bit systems.

This ZeroCleare infection and distribution campaign could be the work of the OilRig threat actors. For initial access, the IP address 193.111.152[.]13 (which was associated with OilRig in recent leaks of Oilrig tools) was used to scan target networks and access accounts as early as fall 2018. One of the IP addresses used to access compromised network accounts in mid-2019 was 194.187.249[.]103, which is adjacent to another IP address, 194.187.249[.]102. The latter was used several months prior to the attack in the xHunt campaign by OilRig.

During the destructive phase, the threat actors brute forced passwords to gain access to several network accounts, which were used to install the China Chopper and Tunna web shells after exploiting a SharePoint vulnerability. The researchers found an additional web shell named "extension.aspx," which shared

similarities with an OilRig tool known as TWOFACE/SEASHARPEE including the methods that were dynamically called from assembly, the use of AES encryption, as well as single-letter variable names.

OilRig (also known as APT34) has been active since late 2015. The group is based in Iran and is believed to be linked to the Iranian government. The actor mainly targets the banking sector, airlines, educational institutions, government entities, and IT and telecommunications companies. The group has had targets in Saudi Arabia, Turkey, Israel, Kuwait, Qatar, the US, the UAE and Lebanon.

APT name	Regions attacked	Operation start
APT33	Middle East, USA, Asia	Fall 2018

A TrendMicro analysis published in mid-November 2019 revealed that threat actors from APT33 use their own network of VPN servers to connect to infected hosts. The researchers say the group focuses on organizations in the Middle East, the United States, and Asia. Infections included two separate locations of a private American company that offers services related to national security. In addition, traces of infection were found in military organizations, universities, and colleges in the US. The investigators also mentioned that there were several victims in the Middle East and Asia.

According to the researchers, for at least two years the group used the private website of a high-ranking European politician (a member of their country's defense committee) to send spear-phishing emails to companies that are part of the supply chain of oil products. The targets included a water facility that is used by the US army for the potable water supply of one of its military bases.

These attacks likely resulted in concrete infections in the oil industry. For example, in the fall of 2018, the researchers observed communications between a UK-based oil company with computer servers in the UK and India and an APT33 C&C server. Another European oil company had the group's malware on one of their servers in India from November to December 2018.

It was also found that the threat actors deployed their own network of VPN servers to manage a targeted botnet. To conceal the connection between the IP addresses of the VPN exit nodes and the botnet, the threat actors used the following obfuscation layers:

- VPN layer — a custom-built network of VPN nodes to hide the operator's real IP address and location
- Bot Controller layer — an intermediary layer of servers
- C&C Backend layer — the actual backend servers through which the group manages its malware botnets
- Proxy layer — a collection of cloud proxy servers through which C&C servers hide from infected hosts

APT33 is a cybercriminal group active since at least 2012. The group targets organizations in different industries in the US, Saudi Arabia, and South Korea. It is particularly interested in the aviation and energy sectors, which are closely connected with petrochemical production. The threat group is thought to be linked to the Iranian government and the Nasr institute, which has in turn been linked to the Iranian Cyber Army multiple times.

APT name	Regions attacked	Operation start
GALLIUM/Soft Cell	South-East Asia, Europe, Africa	2018

Microsoft Threat Intelligence Center (MSTIC) published a warning about continuing attacks targeting telecommunications providers worldwide and controlled by a threat group Microsoft tracks as GALLIUM.

GALLIUM attacks target telecommunications providers in South-East Asia, Europe, and Africa. The threat actors exploit vulnerabilities in WildFly, an open-source application server formerly known as JBoss Application Server.

This activity from GALLIUM has been identified predominantly through 2018 to mid-2019. GALLIUM is still active; however, activity levels have dropped compared to what was previously observed.

Once the threat actors have penetrated a company's network, they start obtaining credentials using common tools and TTPs (tactics, techniques, and procedures). They use stolen credentials and the PsExec utility to move laterally across the network and execute processes on other systems.

Among GALLIUM tools that experts detected being used in previous campaigns are HTRAN (connection bouncer to proxy connections), Mimikatz (authentication token recovery), NBTScan (scanner for open NETBIOS nameservers on a local or remote network), Netcat (reading from and writing to network connections using TCP or UDP protocols), PsExec (executing a command line process on a remote machine), Windows Credential Editor (credential dumper), and WinRAR.

The threat actors rely on web shells to gain persistence within a target's network and drop their payloads.

In addition to standard China Chopper, the threat group uses a native web shell that is based on the China Chopper web shell called BlackMould for various purposes, including enumerating local drives, employing basic file operations, setting file attributes, exfiltrating and infiltrating files, and running malicious commands on compromised devices.

As part of the second stage, the group deploys customized Gh0st RAT and Poison Ivy malware payloads designed to evade detection.

The specified domains, the course of the attack, and the tools used lead us to believe that GALLIUM is another name for Operation Soft Cell, which is at the moment attributed to the Chinese groups APT10 and APT27.

APT name	Regions attacked	Operation start
Platinum	Asia-Pacific region (APAC)	2019

The Platinum hacker group shows new activity using a new tool, a backdoor called Titanium (named after a password to one of the self-executable archives discovered during analysis).

Researchers believe the Titanium backdoor uses local web resources to spread to victim computers. Another way of spreading is the use of a shellcode that needs to be injected into a process. The analyzed campaign involved the winlogon.exe system process, but it is unclear how the shellcode was injected.

To communicate with the C&C server, the malware employs steganography. To prepare a request to the C&C server, it uses the UserAgent string from the configuration and a special cookie generation algorithm. The malware can also get proxy settings from Internet Explorer.

In response to this request, the C&C server answers with a PNG file that contains steganographically hidden data. This data is encrypted with the same key as the C&C requests. The decrypted data contains backdoor commands and arguments for them.

As a result, the backdoor can accept many different commands, with the following among the most interesting ones:

- Read any file from a file system and send it to the C&C server

- Drop or delete a file in the file system
- Drop a file and run it
- Run a command line and send execution results to the C&C server
- Update configuration parameters (except the traffic encryption key)
- Interactive mode, which allows the attacker to receive input from console programs and send their output to the C&C server.

The Platinum hacking group (also known as TwoForOne) has been active since at least 2009 and has mostly been attacking organizations in South and South-East Asia. The members of the group are believed to be from China.

APT name	Regions attacked	Operation start
AVIVORE	Europe, UK	Summer 2018

While it was believed that hacking groups such as China's APT10 orchestrated the attacks against European multinationals in the aerospace and defense industries this year, the threats are actually coming from previously unknown hackers, according to Context, a cybersecurity company. The hacking group, which was named AVIVORE, has been active since 2015, although most of the attacks were only exposed in the past 12 months.

Avivore is believed to be the brain behind recent threats to European aerospace giant Airbus, which were initially attributed to the already well-known Chinese groups APT10 and Jiangsu Province Ministry of State Security (JSSD). Airbus was hit four times this year, most recently in September 2019.

The report says the attackers intruded Airbus's global supplier network through British engine-maker Rolls-Royce, which provides engines for Airbus planes, and French technology consultancy Expleo, in addition to two unidentified contractors working for the aerospace company.

This is reflective of Avivore strategy: the group applies an island hopping technique—which involves attacking a bigger group indirectly, through its network of weaker, less defended partner companies—in a “horizontal” way rather than the more traditional “vertical” one.

This means that instead of targeting partners such as Managed Services Providers (MSPs), which can be easily removed and replaced in the supply chain, the group attacks suppliers that are integrated in their victim's value chain.

Avivore hackers have been masquerading as legitimate users to intrude suppliers' networks, particularly via VPNs and other remote or collaborative working tools. This then let the group bypass the security defenses of the larger company it was targeting, before carefully hiding its activity.

The research report says the hackers were localized in the UTC+8 time zone. The primary objective for their intrusions is believed to be espionage, as well as access enablement through supply chain partners.

APT name	Regions attacked	Operation start
Gamaredon	Ukraine	September 2019

Anomali, a cybersecurity company, reports that the Gamaredon threat group has been attacking Ukrainian diplomats, military officials, and law enforcement.

The actors used spear-phishing with malicious documents attached to the emails to deliver malware. Analysis of these documents revealed that the mail-out started in September 2019 and ended on November 25, 2019.

The experts studied three malicious documents: one of them was addressed to the Dnipro Control System, another was produced by the NGO media watchdog Detector Media, and a third targeted the Ministry of Foreign Affairs of Ukraine.

The initial documents connect to a remote server to download a document template (.dot) that contains VBA macros. The .dot file is executed in the background, while the VBA macro writes a VBScript file to the startup folder. Upon reboot, the VBScript performs an HTTP GET request to fetch a payload. Unfortunately, the researchers did not observe a second-stage payload being delivered.

Gamaredon Group (aka Primitive Bear) is a Russian threat group active since at least 2013. The group first borrowed tools for their attacks, but then started using their own malware. Their attacks target governments, law enforcement, and military organizations mostly in Ukraine.

APT name	Regions attacked	Operation start
APT-C-35	Bangladesh, Thailand, India, Sri Lanka, Philippines, Argentina, UAE, UK, Pakistan	2019

The APT-C-35 group was observed in 2019 in attacks against Bangladesh, Thailand, India, Sri Lanka, and the Philippines, as well as outside Asia—Argentina, the UAE, and the UK.

At the early stage of infection, the victim receives an MS Word document in Office Open XML format. The initial penetration vector is likely a targeted phishing message with an MS Office attachment. The document itself is not malicious, but it abuses the external elements auto-loading capability to launch the next-stage document.

The loaded file is an RTF document that exploits vulnerability CVE-2018-0802 in Microsoft Equation.

Two loaders establish a foothold in the system: Lo2. Despite their classification, the Trojans have different objectives. For instance, the file “Serviceflow.exe” acts as a watchdog. It collects the following information about the system:

- username
- computer name
- contents of \Program Files\ and \Program Files (x86)\
- OS version
- data about the processor

The watchdog records the results in the file “log.txt.” It also checks Windows\Tasks\ for files “A64.dll” and “sinter.exe.” If necessary, it downloads the files from the control server and launches them on behalf of the current user. The corresponding token is extracted from the process winlogon.exe. The sinter.exe Trojan lets the attackers know about the infection by sending a request to a server and sends them the collected information about the system.

As a result of the malicious loaders' activity, components of the yty framework are inserted into the system, allowing the attackers to get more details about their victim, including files with a certain extension, intercepted input strings, list of processes, and screenshots.

APT-C-35 (also known as Donot Team and SectorE02) has been active since at least 2012. The attackers hunt for confidential information and intellectual property. The hackers' targets include countries in South Asia, in particular, the state sector of Pakistan.

APT name	Regions attacked	Operation start
APT20	Brazil, China, France, Germany, Italy, Mexico, Portugal, Spain, UK, USA	2017

Over the last two years, the APT20 group has attacked government entities, bypassing two-factor authentication to collect data.

Specialists at Fox-IT say the group's attacks affected companies in ten countries. The threat actors carried out a global espionage campaign, which was named Operation Wocao and targeted a wide variety of industries, including aviation, construction, finance, health care, insurance, gambling, and energy.

The hackers compromise target network via vulnerable web servers managed by a company or government entity. They then move through the network in search of system administrators with privileged access to the most important parts of the computer system.

APT20 used keyloggers on administrators' computer systems to log keystrokes and steal passwords. The researchers say that in at least one case the group was able to bypass RSA SecureID, a two-factor authentication system, by copying its codes.

The threat actors cover their tracks by regularly deleting tools for stealing data from infected computers. The campaign involves tools such as web shells for file upload and command execution, a script for scanning the system for information the attackers need, the custom XServer backdoor, CheckAdmin to identify if administrators are logged in, and others.

APT20 (also known as APT8, TH3Bug, Violin Panda, and Nitro) has been active since at least 2009. The group primarily attacks the energy, chemical, health care, pharmaceutical, and higher education industries. The purpose of the group's attacks appears to be industrial espionage and theft of intellectual property to gain a competitive advantage. The threat group has carried out two major campaigns: Th3bug, a watering hole campaign, and Nitro, a spear-phishing campaign.

APT name	Regions attacked	Operation start
Rancor	Cambodia	December 2018

In recent attacks, Rancor persistently targeted at least one government organization in Cambodia from December 2018 through January 2019. While analyzing these attacks, researchers discovered an undocumented, custom malware family, which they named Dudell. In addition, they discovered the group using Derusbi, which is a malware family believed to be unique to a small subset of Chinese cyberespionage groups.

Between early December 2018 and the end of January 2019, Rancor conducted at least two rounds of attacks intending to install Derusbi or KHRat malware on victim systems.

The DUDELL sample is a weaponized Microsoft Excel document that contains a malicious macro that runs on the victim's machine. The script downloads a second stage payload via the Microsoft tool msiexec. Unfortunately, at the time of discovery the hosted file was unavailable.

The malware in question is configured with the following single export entry: DllInstall.

The DllInstall export function is responsible for the core behavior of the malware, as just loading it does nothing. Once this export is called, it checks for a hidden window with the caption "Hello Google!" and

the class name "Google." This check is performed to ensure that only one instance of the malware is running at a time.

The hidden window created by the malware filters any user input (e.g. keyboard or mouse activity). This could be an attempt to evade sandbox analysis as mouse and keyboard movement is typically not performed.

The malware then proceeds to beacon to a configured remote server on TCP port 8080. Upon successful connection, the malware transmits victim information such as hostname, IP address and language pack along with other operating system information. The transmitted data is XOR encoded. The malware supports the following capabilities:

- Terminate specific process
- Enumerate processes
- Upload file
- Download file
- Delete file
- List folder contents
- Enumerate storage volumes
- Execute a command
- Reverse shell
- Take a screenshot

Derusbi is a backdoor Trojan believed to be used among a small group of attackers, which includes the Rancor group. The discovered sample is a loader that loads an encrypted payload for its functionality. This DLL requires the loading executable to include a 32-byte key on the command line to be able to decrypt the embedded payload, which was unfortunately not obtained.

Rancor is a Chinese hacking group active since at least 2017. It conducts targeted attacks in South-East Asia and uses politically motivated lures to entice users to open their malicious files.

APT name	Regions attacked	Operation start
BlackTech	Asia-Pacific region	2019

In a recent campaign, security specialists discovered a piece of Waterbear payload with a brand-new purpose: hiding its network behavior from a specific security product by API hooking techniques. Analysis revealed that the security vendor is APAC-based, which is consistent with the countries BlackTech (the group that uses the Waterbear Trojan) targets.

Knowing which specific APIs to hook might mean that the attackers are familiar with how certain security products gather information on their clients' endpoints and networks.

Waterbear employs a modular approach to its malware. It utilizes a DLL loader to decrypt and execute an RC4-encrypted payload. Typically, the payload is the first-stage backdoor, which receives and loads other executables from external attackers. These first-stage backdoors can be divided into two types: first, to connect to a C&C server, and second, to listen in on a specific port. Sometimes, the hardcoded file paths of the encrypted payloads are not under Windows native directories (e.g., under security products or third-party libraries' directories), which may indicate that the attackers might have prior knowledge of their targets' environments.

During their investigation, the experts found a peculiar incident that stood out from most of the Waterbear infections they had previously seen. This time, the DLL loader loaded two payloads: the first payload performed functionalities that had not been seen before: it injected codes into a specific security product to do API hooking in order to hide the backdoor from the product. Meanwhile, the second payload is a typical Waterbear first-stage backdoor.

Both payloads were encrypted and stored on the victim's disk and were injected into the same service, which in this case was LanmanServer. The experts observed that the loader tried to read the payloads from the files, decrypted them, and performed thread injections with the following conditions:

1. If the first payload cannot be found on the disk, the loader will be terminated without loading the second one.
2. If the first payload is successfully decrypted and injected into the service, the second piece will also be loaded and injected regardless of what happened to the first thread.
3. In the first injected thread, if the necessary executable from the security product is not found, the thread will be terminated without performing other malicious routines. Note that it is only the thread that will be terminated, the service will still be running.

In order to hide the behavior of the first-stage backdoor (which is the second payload), the first payload uses API hooking techniques to avoid being detected by a specific security product and to make an interference in the result of the function execution. It hooks two different APIs, namely "ZwOpenProcess" and "GetExtendedTcpTable" to hide its specific processes. The payload only modifies the functions in the memory of the security product process, hence the original system DLL files remain unchanged.

The payload is composed of a two-stage shellcode. The first-stage shellcode finds a specific security product's process with a hardcoded name and injects the second-stage shellcode into that process. The second-stage shellcode then performs API hooking inside the targeted process.

BlackTech is a cyberespionage group operating against targets in East Asia, particularly Taiwan, and occasionally Japan and Hong Kong. Based on the mutexes and domain names of some of their C&C servers, BlackTech's campaigns are likely designed to steal their target's technology. Three main campaigns are linked to the group: PLEAD, Shrouded Crossbow, and of late, Waterbear.

APT name	Regions attacked	Operation start
Tick	Japan, China	2019

As part of their attacks in January 2019, Tick conducted their research by compromising a Japanese economic research company and a public relations (PR) agency to steal email credentials and files as decoy documents. These email addresses were used for spear phishing, prompting potential victim organizations to open the attachments with malware payloads. Meanwhile, the documents were embedded with malware and sent to individuals and companies knowledgeable in Japanese or Chinese and interested in the Chinese economy.

The group's main targets in 2019 were the chemical industry and the defense sector. The campaign was dubbed Operation ENDTRADE.

Malware used in this campaign:

- Datper — can execute shell commands on the victim machine and obtain hostnames and drive information. One sample could also evade anti-virus detections.
- down_new — combines features of existing Trojans in the malware family's development, based on adjustments Tick made.
- Avenger — has a number of variants and versions depending on the targets. For example, some variants have autorun functions while others execute sleep mode upon system infection. Specialists found that the loader has three stages:
    - The first stage collects volume information, AV product, and OS bits version from the host and sends it to the C&C server to ensure that the host is the intended target.
    - It then checks if the host matches their C&C server reference. Avenger collects the victim's detailed information from the system by browsing the folders, files, and domain information.
    - If the host doesn't exist, Avenger will download an image with embedded malware hidden via steganography and extract a backdoor.

- Casper — a modified version of the Cobalt Strike backdoor, showing the team server SHA1 hash if the controller connects to the C&C. If accessed by the client, Cobalt Strike confirms with the user if they recognize and match the SHA1 hash of a specific team server's SSL certificate.
- Open-source tools. For instance, they cloned Lilith RAT from GitHub, studied and implemented its features into their customized backdoor under continued development.

Tick (also known as Bronze Butler and RedBaldKnight) is a threat group active since 2008. Most of their attacks target government entities, IT companies, the defense sector, biotech companies and the electronics industry in South Korea and Japan.

APT name	Regions attacked	Operation start
Golden Falcon	Kazakhstan	2019

In November 2019, experts at Qihoo 360 Netlab published a report describing the activity of the Golden Falcon group (also known as APT-C-34) having accessed one of the group's C&C servers. The threat group carried out an attack against Kazakhstan. The targets included both individuals and organizations such as government agencies, researchers, journalists, private companies, the educational sector, religious figures, government dissidents, and foreign diplomats.

The group's main activity is believed to be focused on espionage, since per-city folders were found on the C&C server, with each city folder containing data collected from infected computers.

It was noted, that the group carried out attacks using phishing, and also used Kazakhstan-based individuals for physical access to devices. The threat actors' arsenal includes both tools developed by themselves and spyware bought from other developers.

There are two main tools: a version of RCS (Remote Control System), a surveillance kit sold by Italian vendor HackingTeam, and Harpoon (*СТС Гарпун* in Russian) that appears to have been developed by the threat actors themselves.

Golden Falcon used RCS version 10.3, while HackingTeam was hacked in 2015 and RCS version 9.6 was leaked. It may be concluded that the hackers purchased the spyware from the supplier.

The experts also mentioned a number of contracts apparently signed by the group. Among the documents are files related to the purchase of Pegasus mobile spyware, a powerful tool for hacking mobile devices on Android and iOS created by the notorious NSO Group. It is unclear whether the deal eventually succeeded, since the attackers did not seem to use the Trojan in their attacks.

Harpoon (*СТС Гарпун* in Russian) had not been seen in other operations of the group. The experts obtained a manual containing the Trojan's main features, which include:

- Keylogging
- Steal clipboard data
- Take screenshot of the active window at predetermined intervals
- List the contents of a given directory
- Get Skype login name, contact list, and chat message history
- Get Skype and Google Hangouts contacts and voice recordings
- Record sound via the microphone, eavesdropping
- Copy a specified file from the target computer
- Automatically copy files from removable media
- Store all intercepted data in an encrypted data file, inside a specified directory
- Send stolen data to a specified FTP server
- Run a program or operating system command

- Download files from a given FTP into a specific directory
- Remotely reconfigure and update components
- Receive data files from a given FTP and automatically extract the files to a specified directory
- Self-destruct

Golden Falcon could be the DustSquad group, which has been active since 2017. DustSquad attacks targeted Kazakhstan, but then the attackers used different malware.

APT name	Regions attacked	Operation start
APT-C-37	Palestine	2019

The APT-C-37 hacking group carried out two targeted attacks. The group conducted remote control attacks by posting files disguised as documents related to the Palestinian Election Conference. The intention was to attack the Palestinian government in order to affect the Palestinian national elections.

The virus samples posted by the attackers were SFX (self-extracting) files, with the icons being disguised as WORD icons.

The encrypted malware is the remote control Trojan Houdini, which first establishes connection with a C&C address, then uses WMI WQL operators to obtain valid information, and sends the information to the C&C server. It then waits for the attacker to respond and send remote control instructions to the victim's machine for the next malicious operation.

APT-C-37 (also known as Pat Bear) has been carrying out targeted attacks against Palestine, Israel, and Egypt since 2015. Typical targets include government agencies, leaders of armed organizations, media personnel, political activists, and diplomats. The group operates from the Middle East.

APT name	Regions attacked	Operation start
Domestic Kitten	Iran, Iraq, Syria, Yemen	2016

Domestic Kitten hackers carried out an operation that uses malicious Android applications to steal confidential information such as screenshots, messages, call logs, surrounding voice recordings, and more. This operation managed to remain under the radar for a long time (it has been ongoing since 2016), as the associated files were not attributed to a known malware family and were only detected by a handful of security vendors.

Whether it is an application that changes the device's background into ISIS-related images, or one that impersonates a legitimate Kurdish news agency, the malicious APKs used by these actors were tailored for specific ethnic groups. Those ethnic groups and minorities can be considered a natural enemy of the Islamic Republic of Iran: Kurds, ISIS supporters, Sunni Muslims, and even Iranian citizens.

The initial infection vector of this attack is still unknown, but specialists believe that the attackers use services such as Telegram to reach potential victims.

Domestic Kitten has been active since at least 2016 and specialists believe the Iranian government is behind it. The attacks affect Android mobile devices and are carried out with the aim of cyberespionage against people that pose a threat to Iranian interests.

APT name	Regions attacked	Operation start
BITTER	China, Kashmir	2019

In August 2019, specialists discovered a new Android Trojan, which was named SlideRAT according to its C&C characteristics. In-depth analysis revealed that the malware family belongs to the BITTER hacker group.

In early November 2019, it was found that SlideRAT attacked personnel engaged in the Chinese military industry. In mid-November, BITTER began attacking Chinese personnel in Pakistan.

The hackers' methods of delivering malware to mobile platforms are mainly watering hole attacks and phishing links, followed by payload delivery via SMS and WhatsApp.

By analyzing the source of SlideRAT, the specialists found that it mimicked multiple legitimate websites for phishing purposes, mainly pretending to be Google Play, Mail ID, and an official tourism website.

In addition to the phishing links, the experts also found that SlideRAT spreads by text messages impersonating a travel company, and uses short links for disguise.

The BITTER group has been active since at least 2015 and is believed to represent Indian interests. BITTER APT campaigns primarily target China, Pakistan, and Saudi Arabia. The group's arsenal includes a similarly-named remote access Trojan called BitterRAT and a downloader mobile family called ArtraDownloader.

Data leaks

- LifeLabs, a Canadian medical company, paid hackers a ransom (the sum has not been revealed) to regain access to the information on 15 million customers, including their names, residence addresses, email addresses, usernames, passwords, and health card numbers. The hackers breached the company's systems, extracted customer data, and then demanded a ransom to give the company back its data.
- OnePlus, a phone manufacturer, reported that it had been compromised, with hackers obtaining their online store information and user data. The threat actors were able to access the following data: customer names, contact phone numbers, and email and delivery addresses. OnePlus assured they removed the vulnerability, conducted a thorough audit of their website in search of other similar problems, cooperated with law enforcement agencies, and were carrying out further investigations.
- Experts Bob Diachenko and Vinny Troia discovered an open Elasticsearch server, which was accessible without authentication and contained four terabytes of data with four billions user accounts. The data pertained to 1.2 billion unique individuals. Analysis of the discovered data led specialists to believe that the information belonged to data brokers People Data Labs and OxyData. The database contained continuously updated aggregated from various sources.
- A 179-GB cloud storage database of Best Western, a hotel chain, was exposed online. The database contained the personal data of the company's customers.
- According to Have I been pwned, a service that helps determine whether your data has been compromised in a data breach, the recent hacking of Zynga affected 170 million users. At the moment, the Zynga hack ranks 10th among all-time largest hacks of user information. Zynga admitted in September that some log-in information for Draw Something and Words With Friends may have been accessed. Zynga has not revealed the details about the scale of the breach and the number of affected users, but a hacker named Gnosticplayers, who claims they accessed two database dumps with names, email addresses, login IDs, phone numbers, and passwords, said that this data included Zynga accounts.
- On December 19, 2019, researcher Bob Diachenko and specialists at Comparitech announced they had discovered an unsecured Elasticsearch database containing 267 million Facebook users (most of the information belonged to US users). The database contains user IDs, phone numbers, and names. The experts believe the database belonged to a Vietnamese threat group, which is why instead of reaching out to the owners of the database, they directly contacted the internet service provider, which removed access to that information immediately after receiving the researchers' warning.

  The specialists say the database was left exposed on the web for at least two weeks (it was first indexed on December 4, 2019).
- An Elasticsearch server of Honda North America was exposed online from October 21 through December 11, 2019. The company officially admitted there had been a data leak affecting 26,000 customers.
- On November 27, 2019, an unknown individual published the details of 15 million bank cards of Iranian citizens, customers of Mellat, Tejarat and Sarmayeh banks. It is unclear who is behind the data leak and how the data was obtained.
- In November 2019, hacker Phineas Fisher announced that back in 2016 they hacked Cayman Bank and Trust Company, an offshore bank, and stole documents and emails of its employees. The hacker made 2 TB worth of the bank's data public. The Cayman National group admitted there had been an attack and said they opened a criminal investigation. The hack affected two legal entities in the Isle of Man: Cayman National Bank (Isle of Man) Limited and Cayman National Trust Company (Isle of Man) Limited.

- A large database with tens of millions of SMS messages, most of which had been sent by companies to potential buyers, was discovered exposed online. The database belonged to TrueDialog, an SMS provider for businesses and higher education institutions that helps companies, colleges, and universities send mass text messages to buyers and students. The database affected over 100 million users.
- The Singapore Accountancy Commission exposed the personal data (names, national identification numbers, dates of birth, and employment information) of candidates of the Singapore Chartered Accountant Qualifications program. The data was accessible between June 12 and October 22, 2019, with 6,541 entries affected.
- The German mobile operator T-Mobile reported a major data leak. T-Mobile's cybersecurity team detected unauthorized access to the personal data of more than one million customers. The stolen data did not contain financial information, social security numbers, or passwords. The threat actors gained access to the users' names, billing addresses, phone numbers, and account numbers. The company said the cyberattack was stopped, but the data of up to 1.5% of T-Mobile may have been compromised. The German mobile operator has about 75 million customers.
- Researcher Troy Hunt reported that the personal information of 1.4 million users of cryptocurrency platform GateHub was exposed online. The 3.72-GB database included email addresses and account passwords at GateHub and was published on a hacker forum. The database owner says it also includes two-factor authentication keys, mnemonic phrases, and wallet hashes. Hunt said analysis of a representative sample of accounts confirmed the authenticity of the data. All of the email addresses he checked were registered at GateHub.
- TennCare, a state Medicaid program, reported a data leak that affected over 40,000 TennCare members and contained names, social security numbers, health plans, and names of prescribed drugs. The compromise was a result of a phishing attacks against an employee of Magellan Health, TennCare's partner.
- In Malaysia, the BreachDB hacker group contacted a media outlet and said they had data on 50,000 students of Universiti Malaysia Sabah. The hackers provided a sample and demanded 50 BTC for the full database.
- ESET specialists discovered a misconfigured Elasticsearch database containing the personal data of Colombian citizens. The database has over 2.5 million entries containing names, email addresses, and phone numbers. The owner of the database has not been identified.
- An unsecured server of Pouring Pounds Ltd (UK) with data on customers in the UK and India was found publicly exposed. The data leak affected over three million individuals: full names, phone numbers, email addresses, account information, and IP addresses.